COMP4127/COMP7850

Information Security

IPSec, TLS, VPN and HTTPS

Reading: Textbook 16,17

Extra reading: William Stallings, Network Security Essentials 4th Ed, Chap 5 and 8

Outline

- Basic of network communication
- IPSec
- TLS/SSL
- HTTPS

Some images of the slides are adopted from the Textbook and Extra readings

Network Model

Communication at two machines is achieved by communication

- at each of these 7 layers between two machines (App-to-App, Phy-to-Phy); and
- between each layers at one machines (App-to-Pre, Data-to-Phy)

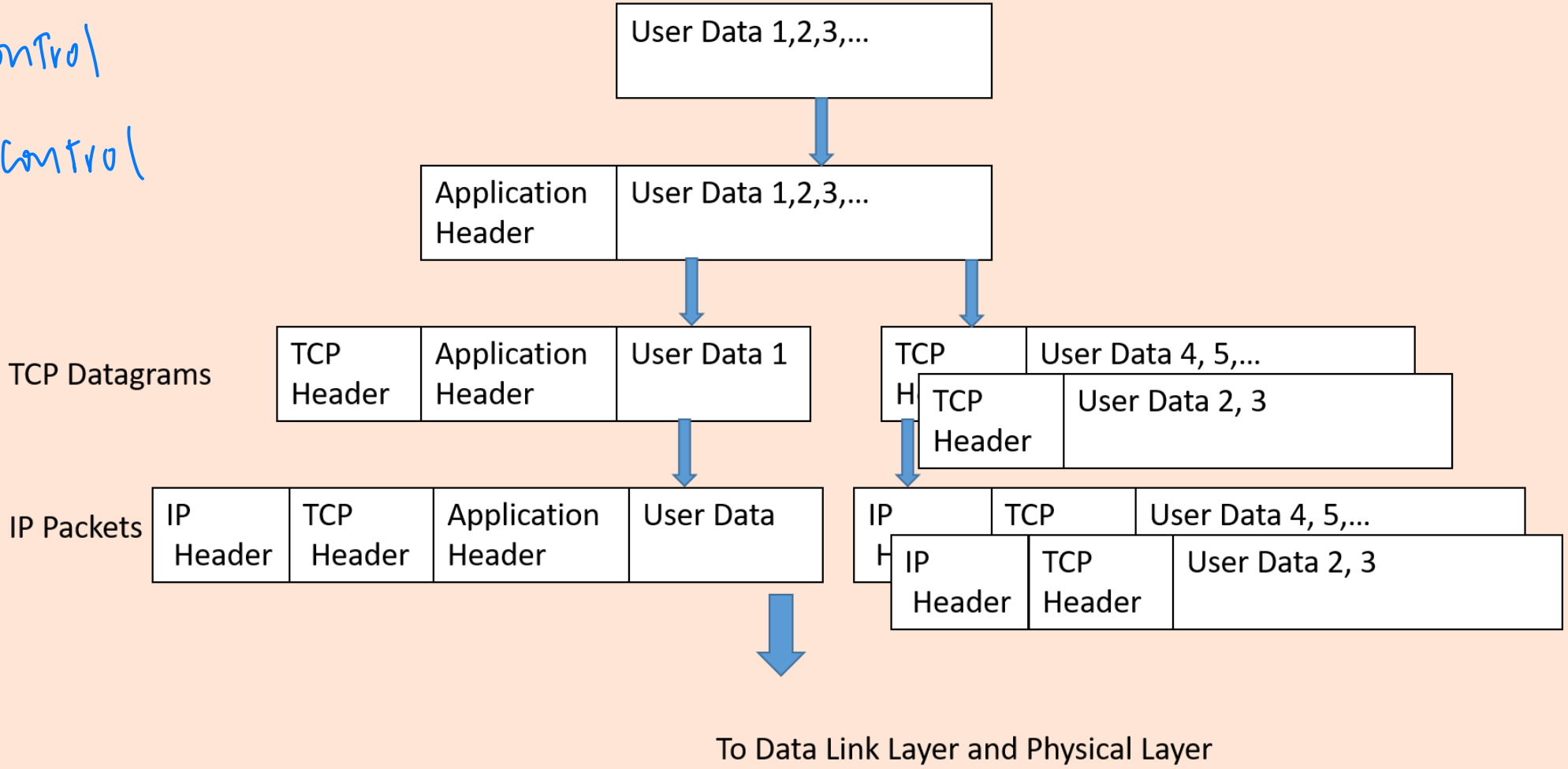
Quick Ref:
https://www.webopedia.com/quick_ref/OSI_Layers.asp

1. Application Layer
2. Presentation Layer
3. Session Layer
4. Transport Layer – TCP/UDP
5. Network Layer - IP
6. Data Link Layer
7. Physical Layer

Transport and Network Layer

① Error control

② Traffic control



How TCP/IP works

- TCP/IP is a suite of protocols that are used to connect hosts on the Internet.
- It is composed of two layers: the **Internet layer** and the **transport layer**.

Internet Layer

- The Internet layer is responsible for routing packets from one host to another.
- It is composed of two protocols: the **Internet Protocol (IP)** and the **Internet Control Message Protocol (ICMP)**.
- IP is responsible for delivering packets from one host to another.
- ICMP is responsible for reporting errors in the delivery of packets.
- In IP routing, each host has a unique **IP address** so that routers can forward packets to the correct destination.

Transport Layer

- The transport layer is responsible for delivering data from one application to another.
- It is composed of two protocols: the **Transmission Control Protocol (TCP)** and the **User Datagram Protocol (UDP)**.
- TCP is responsible for delivering data reliably and in order.
- UDP is responsible for delivering data without any guarantees.
- TCP and UDP are **connection-oriented protocols**, which means that a connection must be established before data can be exchanged.

Name Resolution

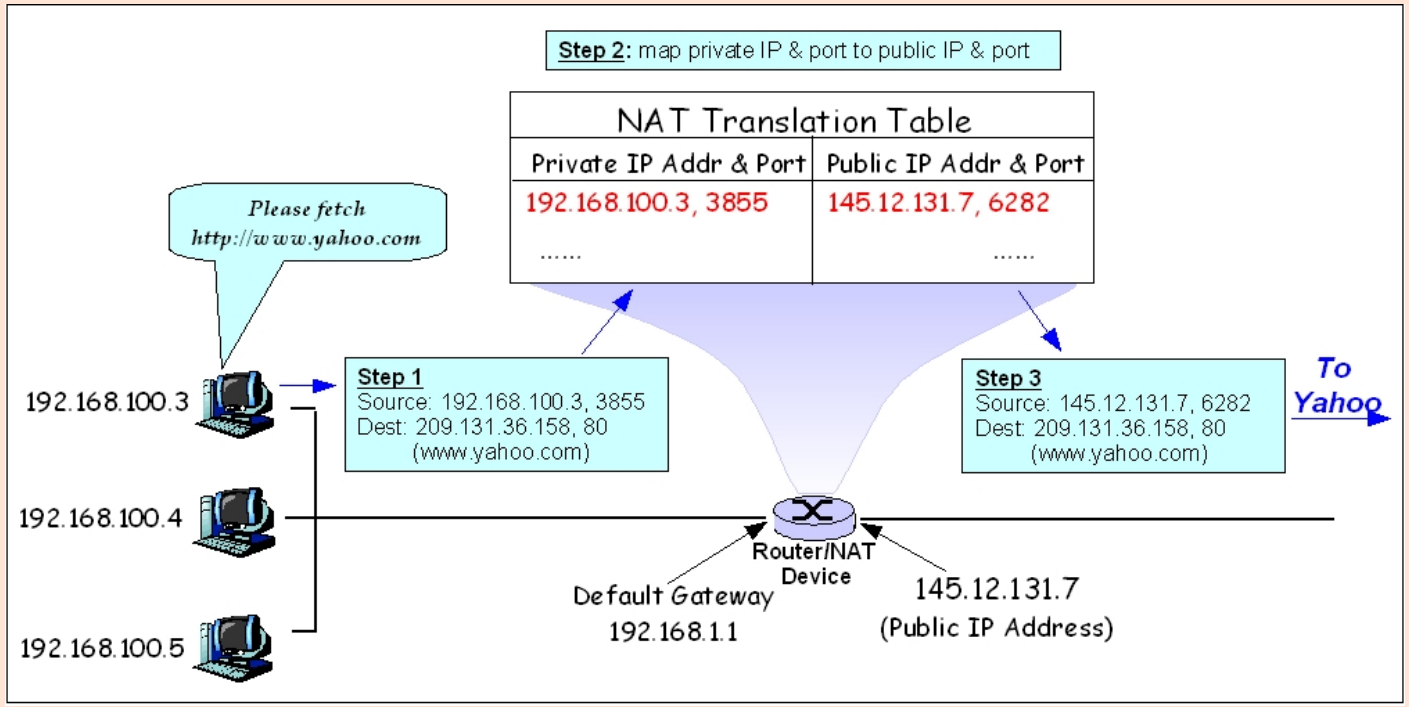
- The Internet layer uses IP addresses to identify hosts.
- However, it is difficult to remember IP addresses.
- Therefore, the Internet layer also provides a **name resolution service**.
- The name resolution service is responsible for translating host names into IP addresses.
- The name resolution service is provided by the **Domain Name System (DNS)**.

```
> nslookup www.google.com
Server:  dns1.comp.hkbu.edu.hk
Address:  158.182.7.12

Non-authoritative answer:
Name:    www.google.com
Addresses:  2404:6800:4005:81c::2004
            142.250.66.100
```

Network Address Translation (NAT)

- NAT is a technique that allows a single IP address to be shared by multiple hosts.
- NAT is used to hide the internal network from the Internet.
- It is useful when there is insufficient IP addresses for network hosts.



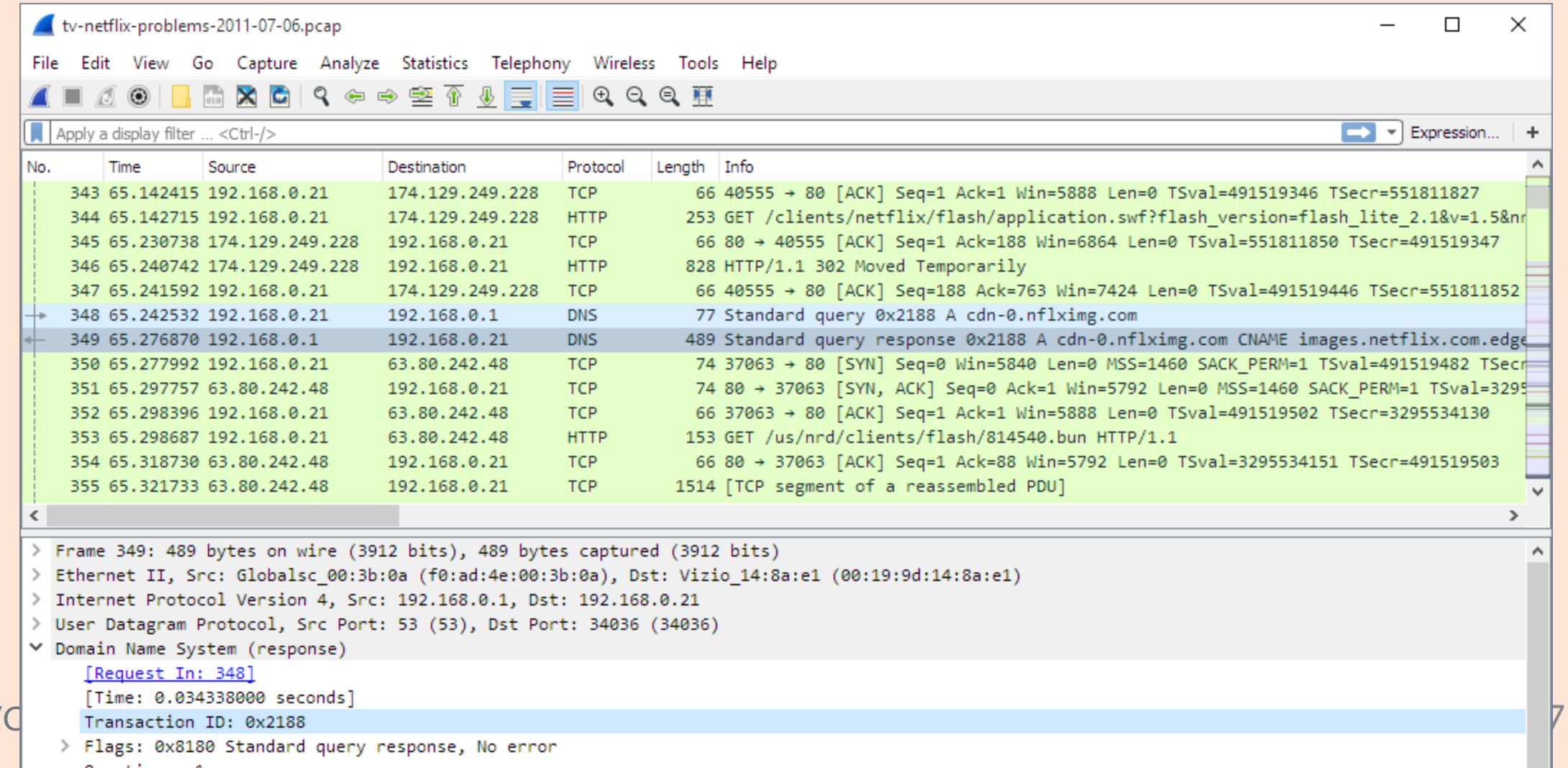
img source: https://en.wikipedia.org/wiki/Network_address_translation

Ideal Security Goal

1. End-to-End Encryption. The data is only accessible by the sender and the receiver. No middle person has the capability to decrypt it. (Proxy server? Firewall? Security Agency? Server?)
2. Tunneling. The traffic pattern is hidden. Except the very last end point, no one in the middle shall recognize the flow of the traffic (how to route then?)
3. Authentication. Packets are authentic.
4. Fast.
5. Free.

Hands-on Work

Before any security has been implemented, try to look at the clear traffic by Wireshark (https://youtu.be/Hl0IpoS503A?t=248)



Where should security be placed

OSI model (or when TCP, IP were developed) was not security aware.
Put security (encryption) in:

- Application Layer: simplest way. Data is secured but not meta-data.
- Physical/Data Link: provides only hop-to-hop security.
- IP Layer: IPSec
- Transport Layer: TLS/SSL
- Upper Layer: HTTPS

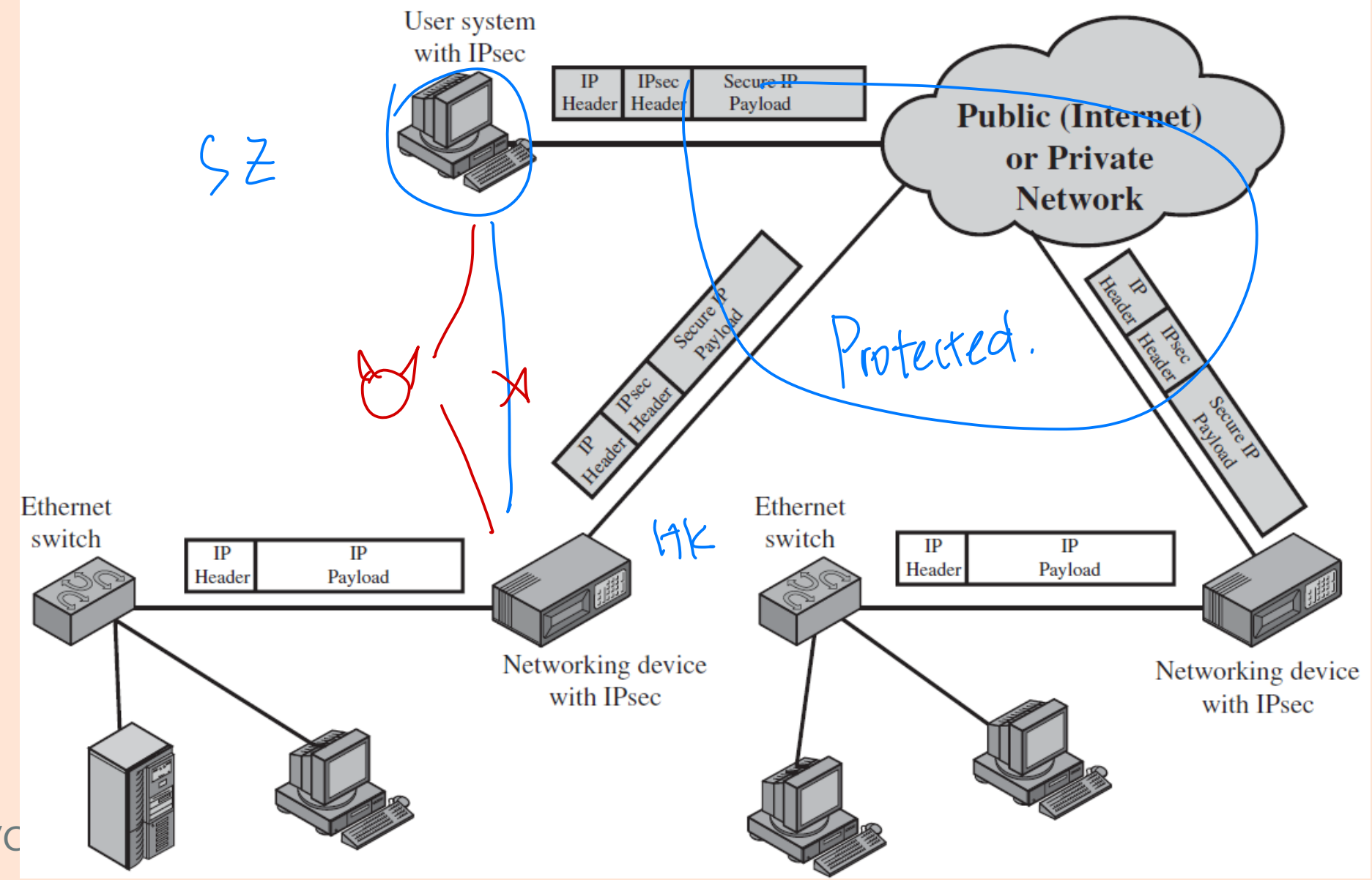
IP Security (IPSec)

IPSec provides the capability to secure communications across a LAN, private WAN, or Internet. Used at:

- Secure branch office connectivity over the Internet
  Secure remote access over the Internet
- Establishing extranet and intranet connectivity with partners
- Enhancing electronic commerce security

IPSec support varies applications in *data encryption*, *authentication*, and *key management*.

IP Security Example



IPSec Specification

Specified in RFC4301, 4302, 4303, 4306

- Architecture - states the overview architecture
- ESP Protocol - To encapsulate / encrypt
- AH Protocol - To authenticate
- Internet Key Exchange (IKE) - The authentication key exchange protocol for IPSec
- SA - To specify what algorithm to use

IP Traffic Processing

IPSec is executed on a packet-by-packet basis.
Outbound packets

- IPSec searches the security policy database for a match.
- Discard if no match
- If the policy say BYPASS - just send right away
- If the policy say PROTECT - look for a key to encrypt
  - Run IKE if no key is found.

Inbound packets

- If it is a bypassed packet (raw IP), look at the database and discard if no match.
- If it is a protected packet, retrieve the SA from database and processed with ESP or AH.

Security Association (SA)

Can be understood of the "choose of parameter".

- SPI: A local identifier enables receiving system to select the SA.
- IP Destination: Unicast receiver address
- Security Protocol: indicates it is an AH or ESP security association

IPSec Services

Authentication Header

Two protocols (AH/ESP) to provide the following services:

Service	AH	ESP (encryption only)	ESP (encryption + authentication)
Access control	✓	✓	✓
Connectionless integrity	✓		✓
Data origin auth	✓		✓
Rejection of replayed packets	✓	✓	✓
Confidentiality		✓	✓
Limited traffic flow confidentiality 机密		✓	✓

Not all of the traffic

Two modes of operations

Both AH and ESP support two modes of operations

Transport Mode

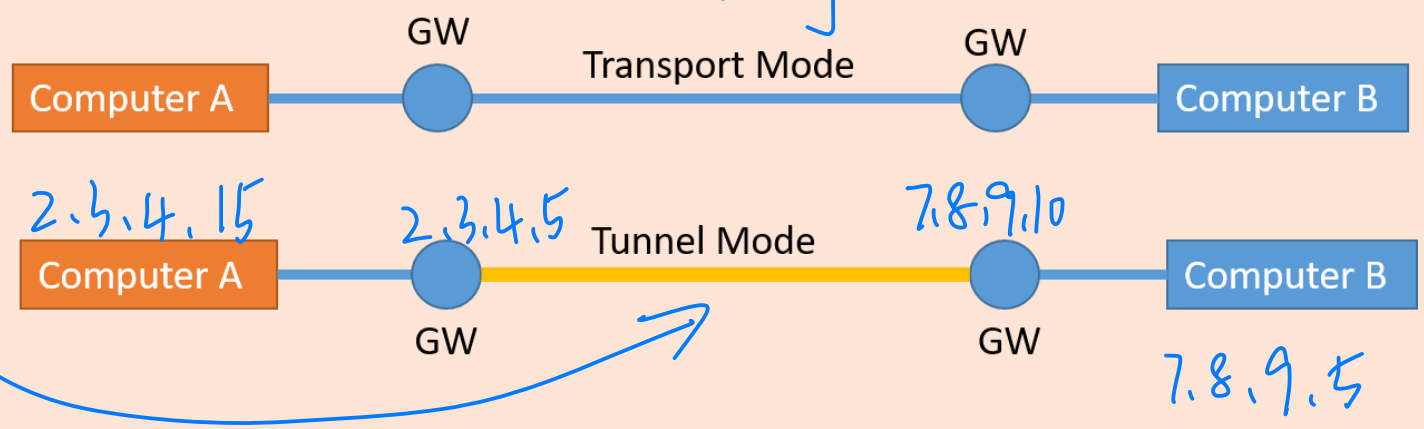
- Provide protection primarily for upper-layer protocols (e.g. TCP/UDP).

Tunnel Mode

- Provide protection to the entire IP packet

P23

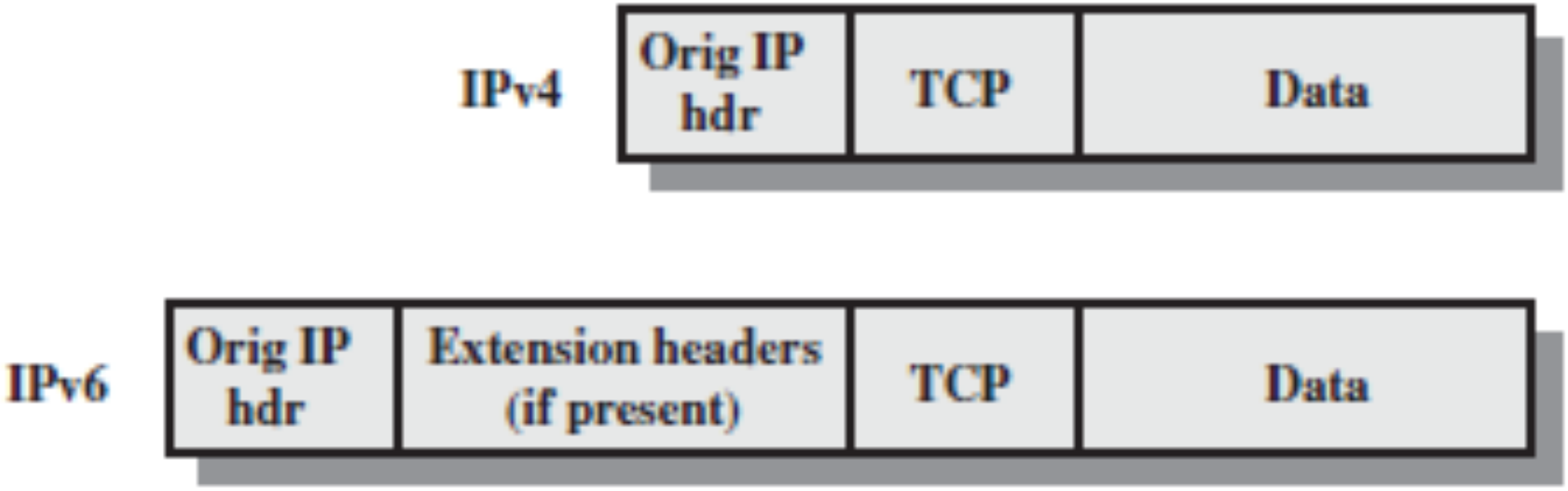
only data.



Two modes of operations

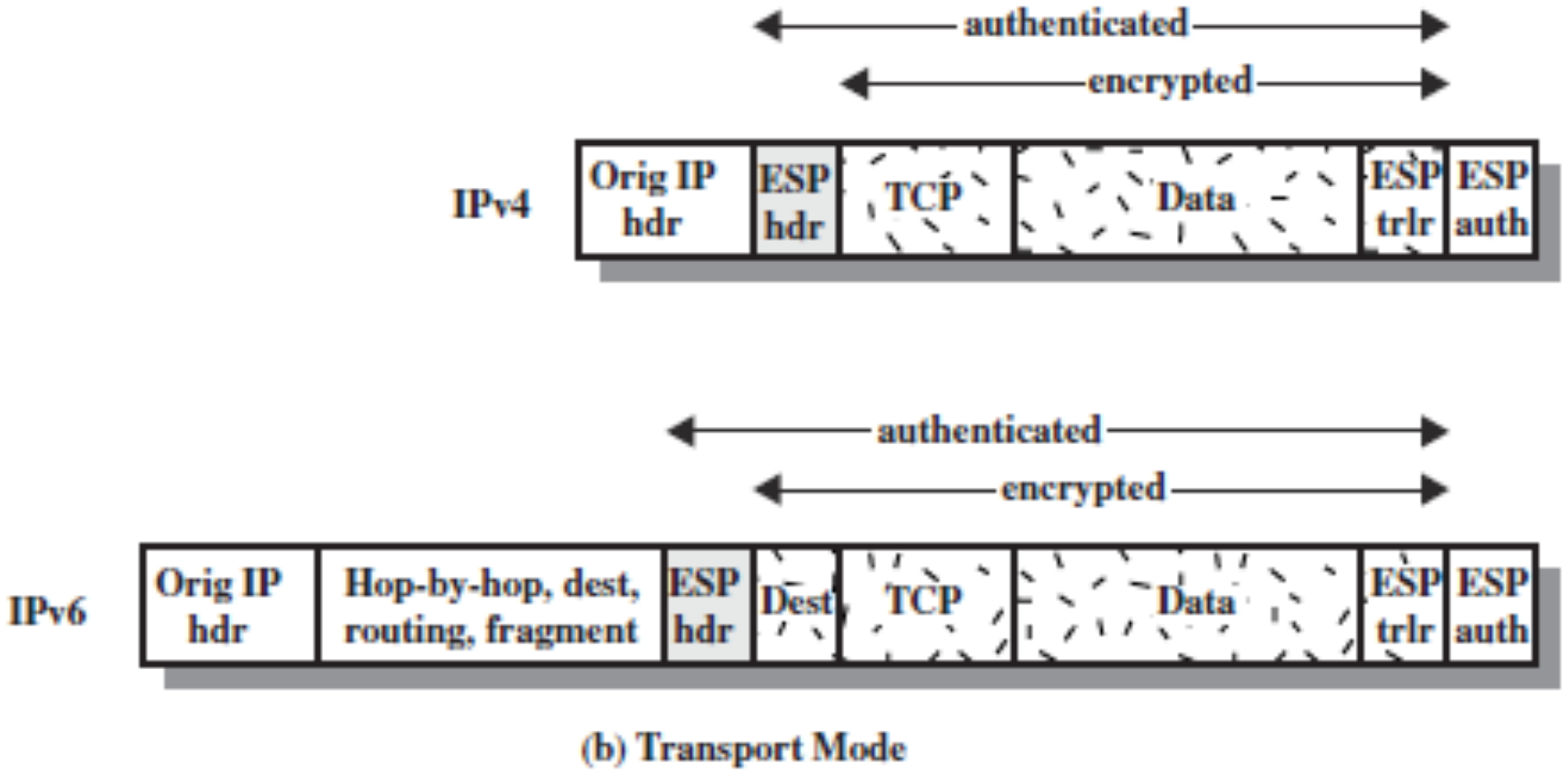
	Transport Mode SA	Tunnel Mode SA
AH	Authenticates IP payload and selected portions of IP header and IPv6 extension headers. TCP header known	Authenticates entire inner IP packet (inner header plus IP payload) plus selected portions of outer IP header and outer IPv6 extension headers.
ESP	Encrypts IP payload and any IPv6 extension headers following the ESP header.	Encrypts entire inner IP packet.
ESP with Authentication	Encrypts IP payload and any IPv6 extension headers following the ESP header. Authenticates IP payload but not IP header.	Encrypts entire inner IP packet. Authenticates inner IP packet.

ESP



(a) Before Applying ESP

ESP Transport Mode

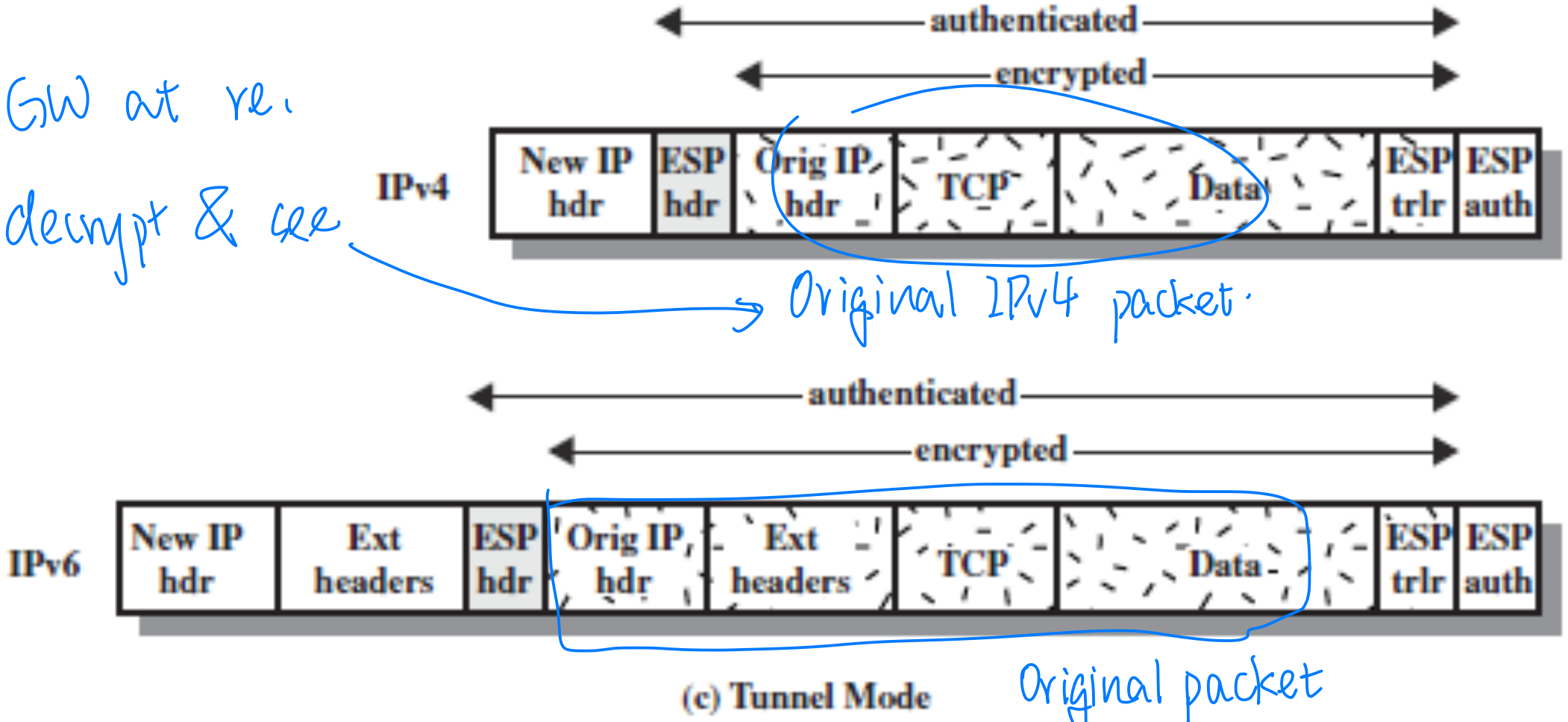


(b) Transport Mode

ESP

GW at re.

decrypt & see

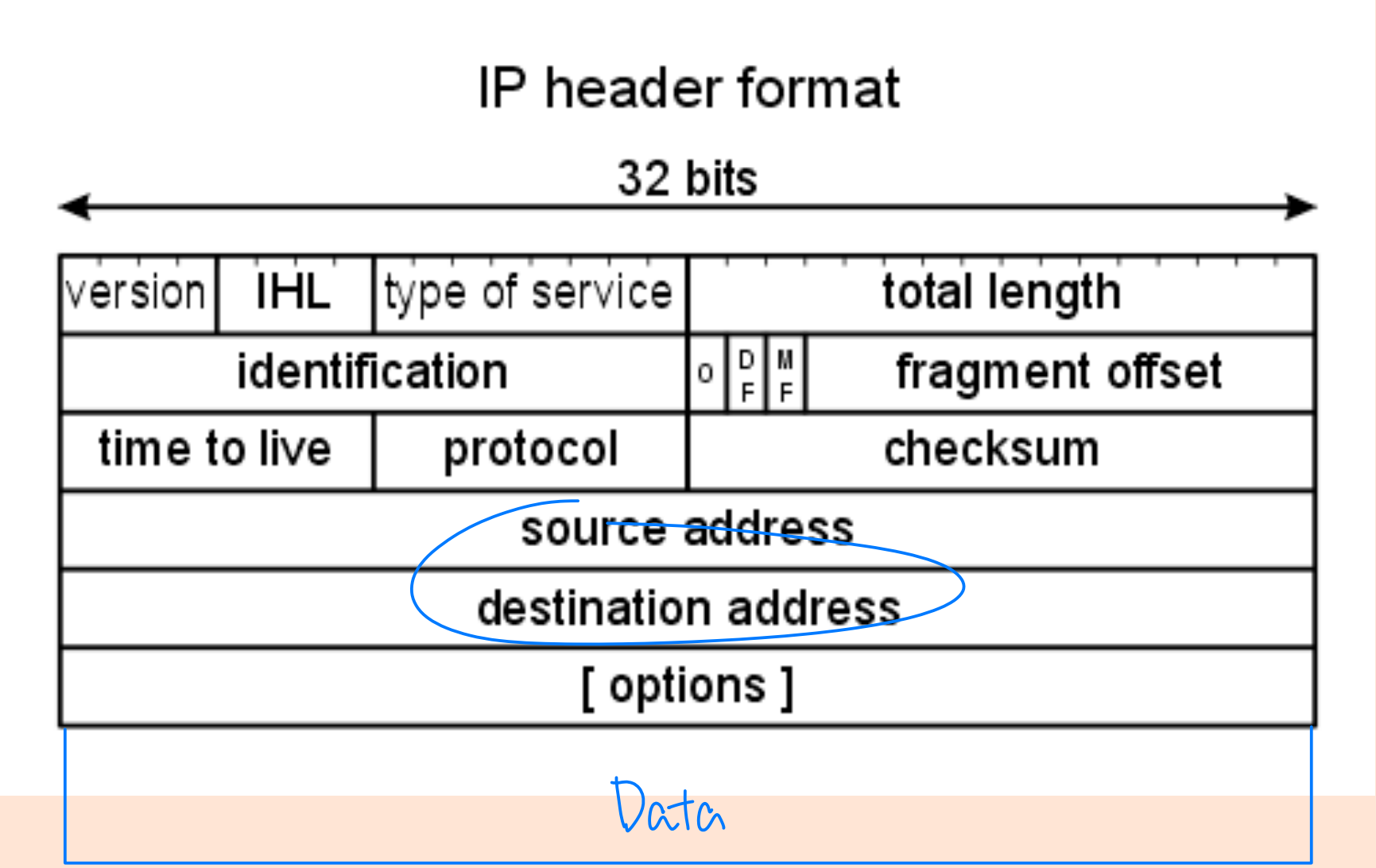


Original IPv4 packet.

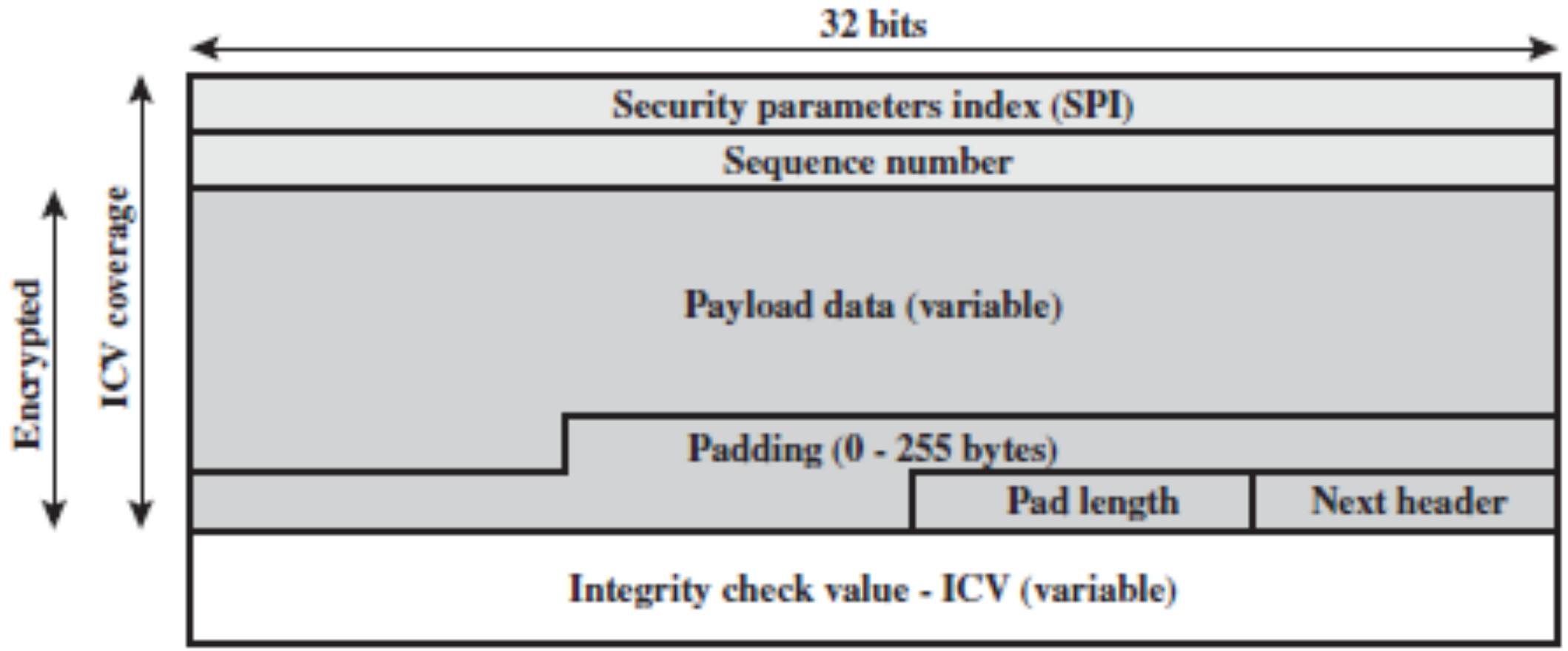
(c) Tunnel Mode

Original packet

Original IP Header



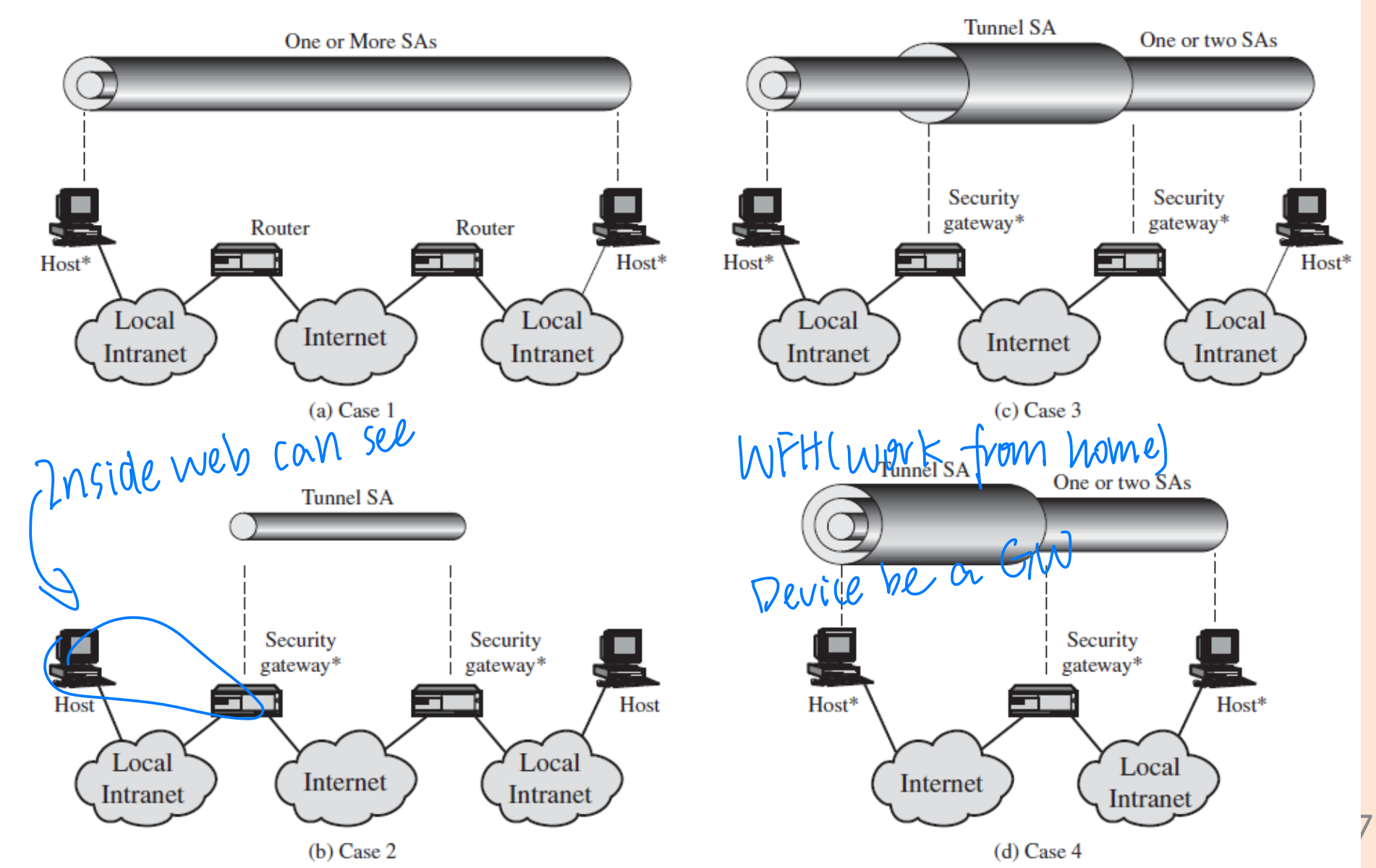
ESP Header


32 bits
Security parameters index (SPI)
Sequence number
Payload data (variable)
Padding (0 - 255 bytes)
Pad length
Next header
Integrity check value - ICV (variable)
Encrypted
ICV coverage

ESP Header Explanation

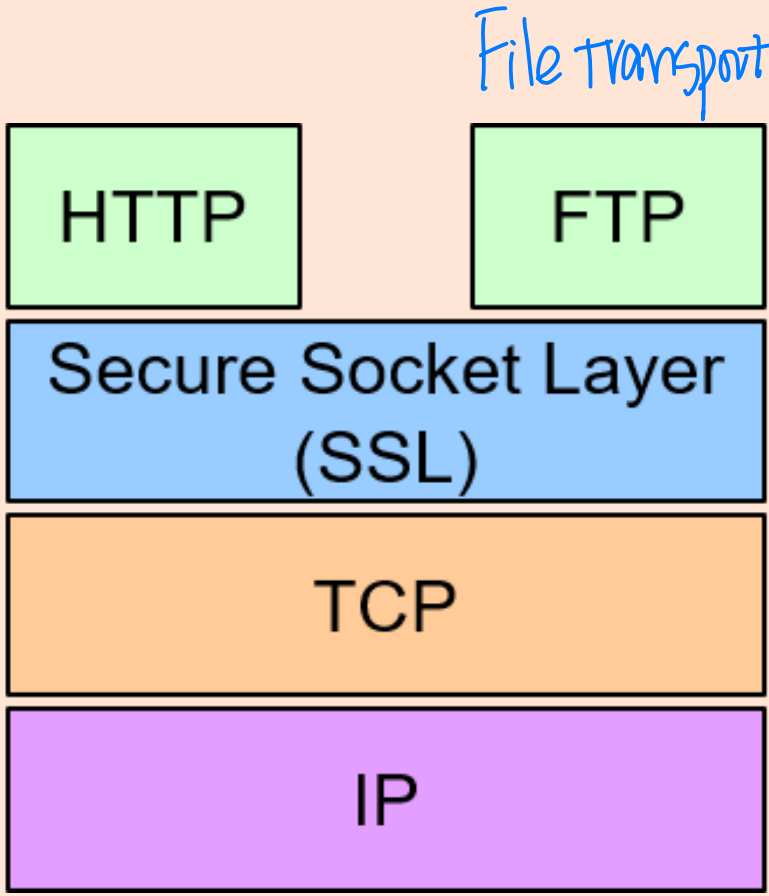
- Security Parameters Index: Identify a SA
- Sequence Number: A counter to provide **anti-replay** function.
- Payload Data: data to carry.
- Padding / Pad Length: For padding purpose
- Next Header: identifies the type of data contained in the payload data field. (e.g., is the payload a TCP data?)
- Integrity Check value: for data integrity .

Basic Combinations of SA



SSL → TOS

- Cryptographic protocols which provide secure communications on the Internet
- Encrypts network connections at the Transport Layer
- Designed to prevent eavesdropping, tampering, and message forgery
- Transport Layer Security (TLS) successor of SSL
- Use TCP to provide a reliable end-to-end service
- Widely used in applications like web browsing (https), e-mail, Internet faxing, instant messaging and other data transfers



SSL

- Encrypted communications over Internet
- Ensures that the information is sent unchanged, and only to the server you intended
- Uses asymmetric encryption for authentication and key exchange (aes)
- Uses a symmetric encryption to encrypt data
- Netscape and Internet Explorer support SSL
- Web sites use SSL to obtain confidential user information, such as credit card numbers.
- URLs that require an SSL connection start with https: instead of http:.

security

SSL Connection and Session

one key only

1 connection & mutiple tasks

Two important concepts to know:

- **SSL Connection**: A connection is a transport that provides a suitable type of service. For SSL, such connections are peer-to-peer relationships. The connections are transient. Every connection is associated with one session.
- **SSL Session**: An SSL session is an association between a client and a server. Sessions are created by the Handshake Protocol. Session define a set of cryptographic security parameters used in multiple connections. For example, one session key is used in multiple connections.

Three Types of Handshaking:

One-way Authentication

- clients can validate the identity of the server (via checking the server's digital certificate)

Two-way Authentication

- communicating parties authenticate each other mutually

Abbreviated Handshake

- restart handshake or resumed handshake, to restart an old connection without going through any asymmetric encryption

SSL

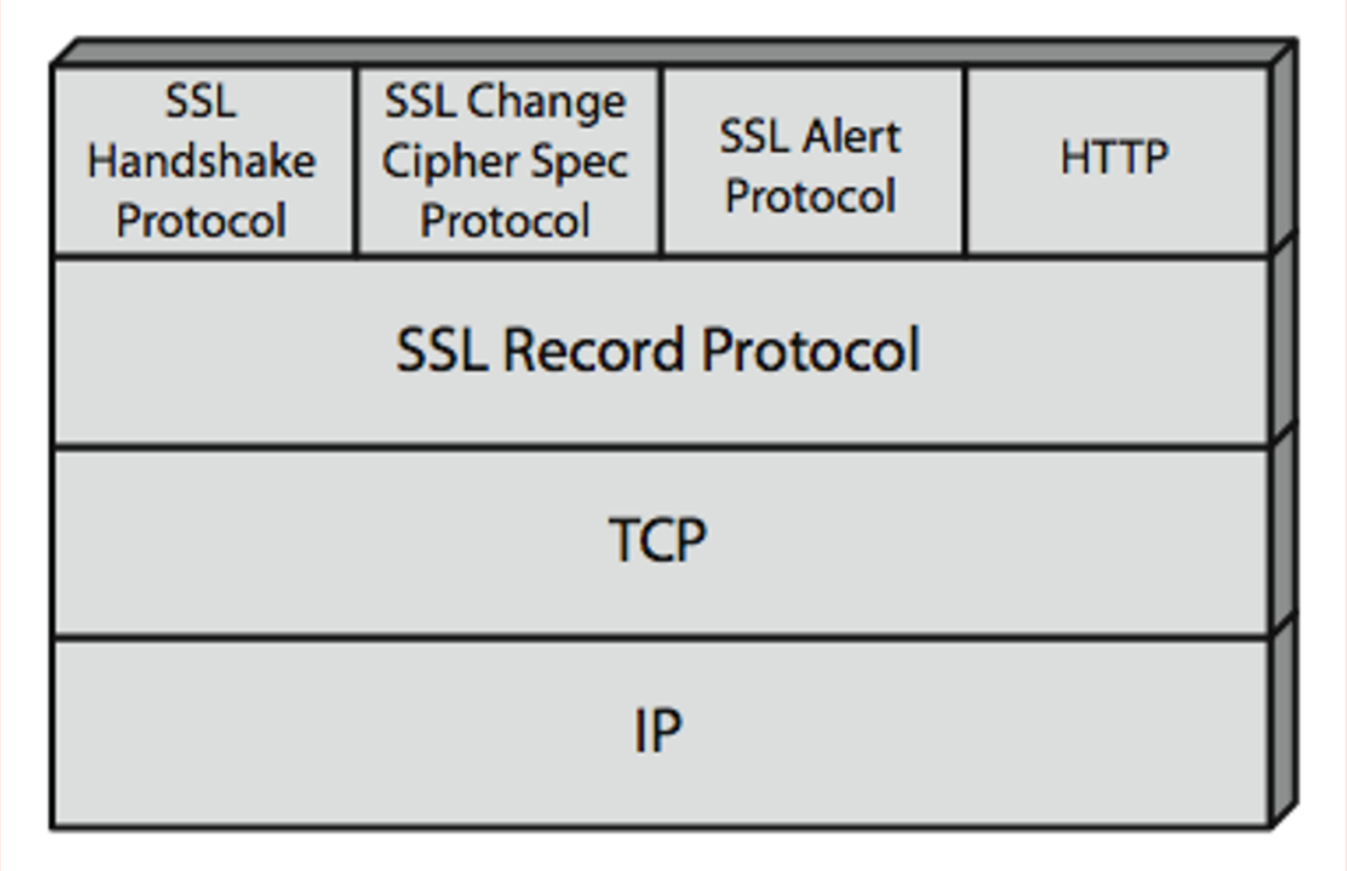
SSL has a protocol stack with two layers of protocols
Lower Layer:

- SSL Record Protocol

Upper Layer:

- SSL Handshake Protocol
- SSL Change Cipher Spec. Protocol
- SSL Alert Protocol
- Application Protocol

SSL Protocol Stack

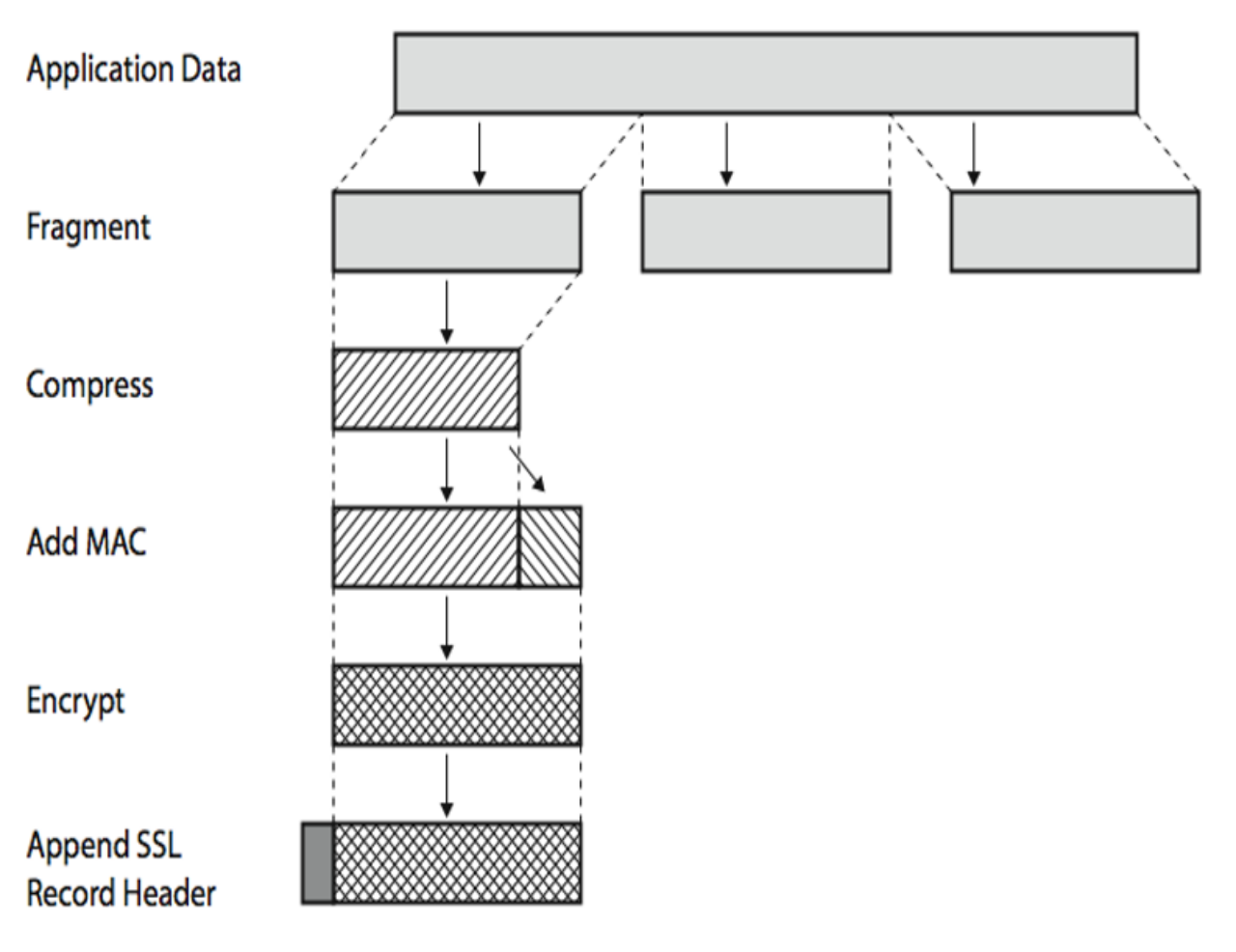


SSL Protocol Stack

SSL Record Protocol

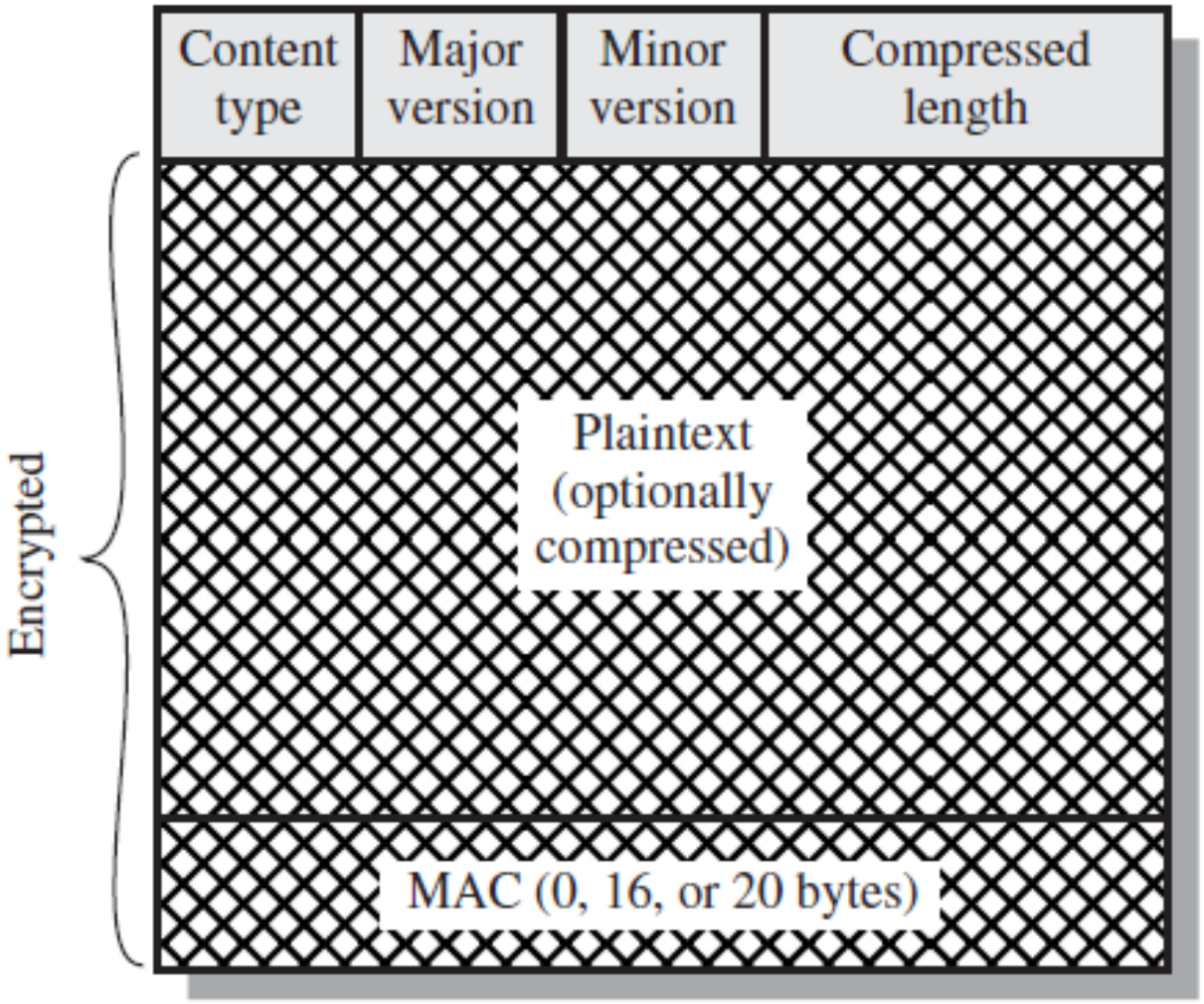
To provide supports to upper layer protocols

- Message integrity
- Confidentiality

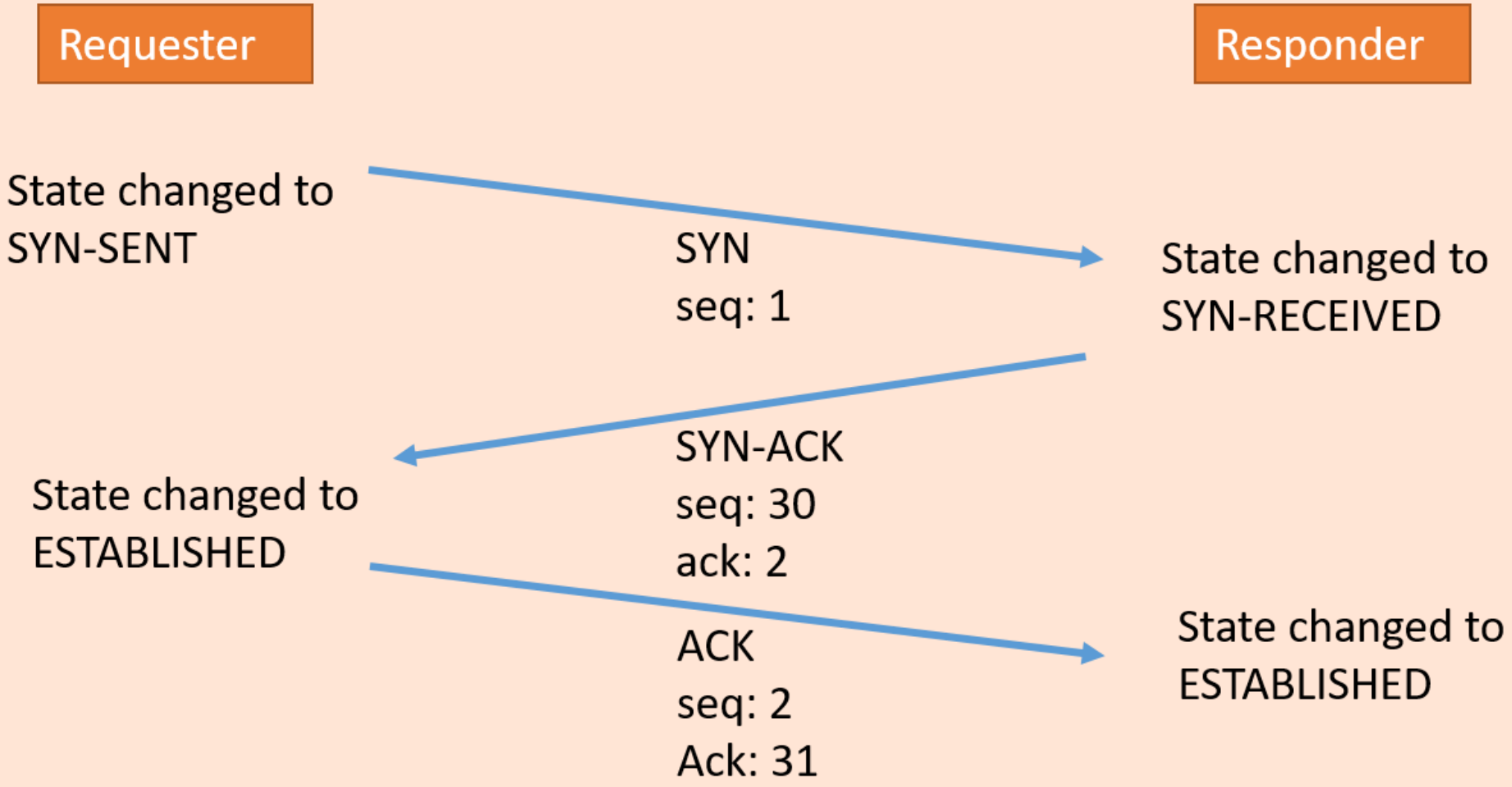


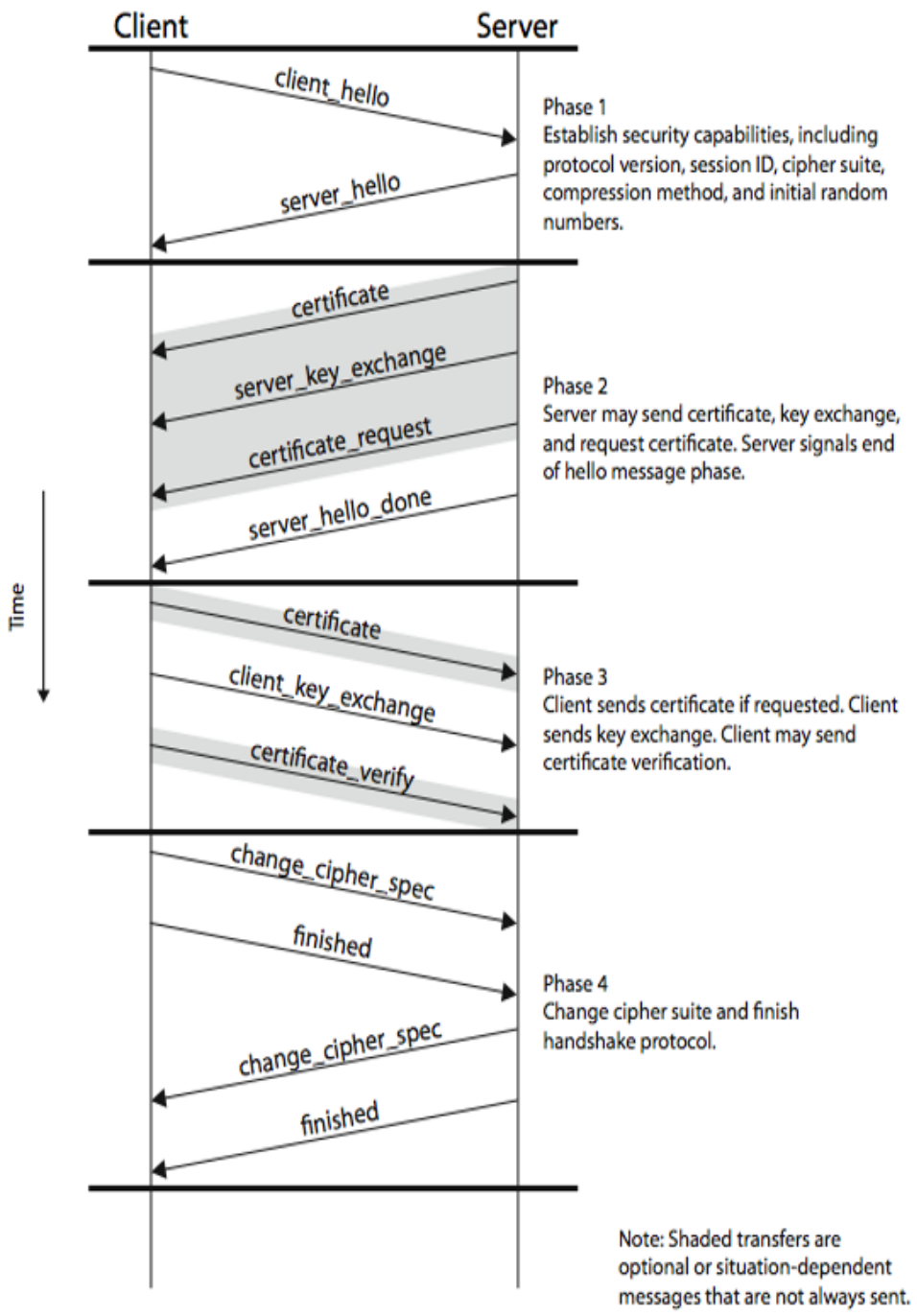
SSL Record Protocol

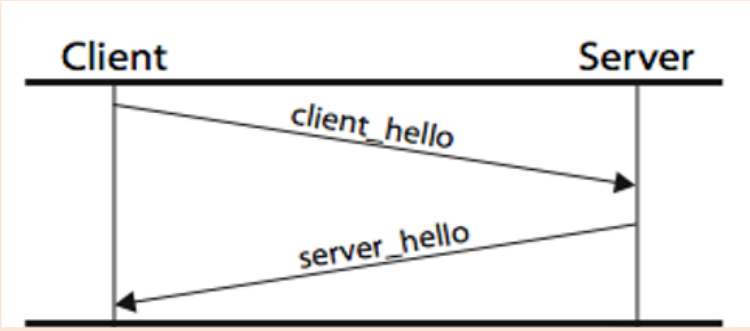
- Fragmentation: Cut the data into 2^{14} bytes or less.
- Compression: Optionally, but must be lossless.
- Add MAC: compute a message authentication code (see chapter 3).
- Encrypt: Message + MAC are encrypted using symmetric encryption.
- Final step: add a SSL header.



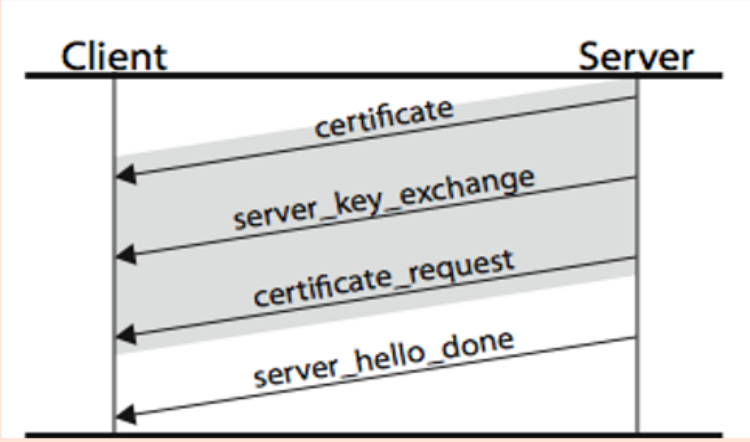
TCP 3 Way Handshake



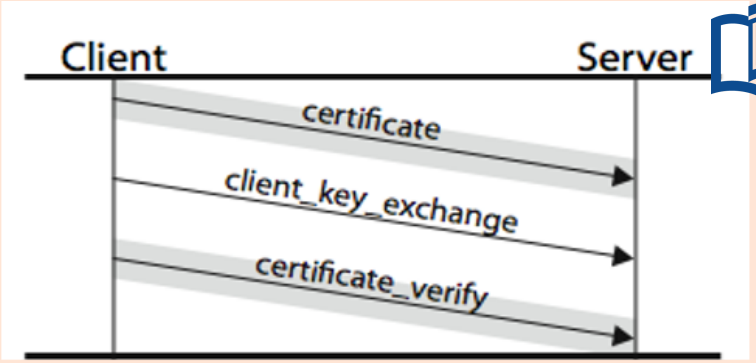

Client
Server
client_hello
server_hello
Phase 1
Establish security capabilities, including protocol version, session ID, cipher suite, compression method, and initial random numbers.
certificate
server_key_exchange
certificate_request
server_hello_done
Phase 2
Server may send certificate, key exchange, and request certificate. Server signals end of hello message phase.
Time
certificate
client_key_exchange
certificate_verify
Phase 3
Client sends certificate if requested. Client sends key exchange. Client may send certificate verification.
change_cipher_spec
finished
change_cipher_spec
finished
Phase 4
Change cipher suite and finish handshake protocol.
Note: Shaded transfers are optional or situation-dependent messages that are not always sent.



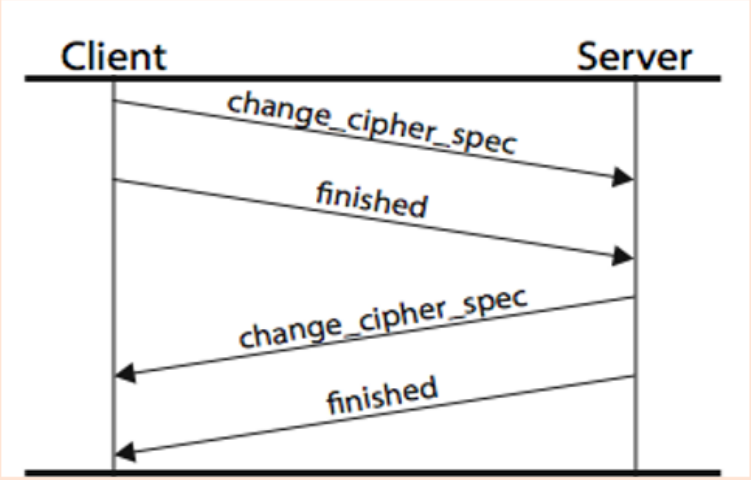
Phase 1:
Establish security capabilities, including protocol version, session ID, cipher suite, compression method, and initial random numbers.



Phase 2:
Server may send certificate, key exchange, and request certificate. Server signals end of hello message phase.



Phase 3:
Client sends certificate if requested. Client sends key exchange. Client may send certificate verification.



Phase 4:
Change cipher suite and finish handshake protocol.

Note: Shaded transfers are optional or situation-dependent messages that are not always sent.

HTTP

- HTTP refers defines operations `GET`, `POST`, `PUT` and other header format definitions for web communication.

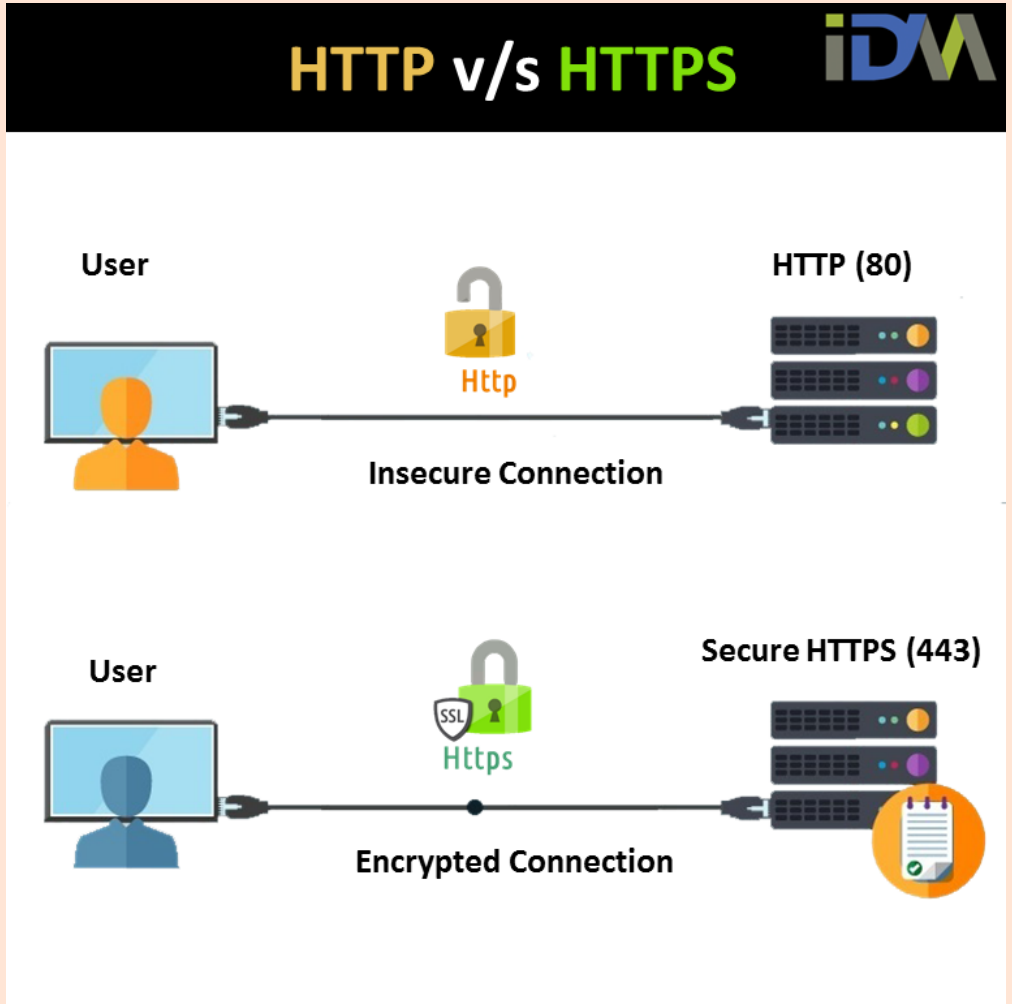
```
GET /index.html HTTP/1.1
Host: www.example.com
User-Agent: Mozilla/5.0
Accept: text/xml,application/xml,application/xhtml+xml,text/html*/*
Accept-Language: en-us
Accept-Charset: ISO-8859-1,utf-8
Connection: keep-alive
```

An ordinary HTTP header

It expose which document you are accessing!

HTTPS

- HTTPS refers to Hypertext Transfer Protocol Secure, or HTTP over TLS/SSL, is a combination of HTTP and SSL to implement secure communication between a client (e.g. Browser) to a Web server.
- HTTPS is documented in RFC 2818. Typically it uses port **443**.



img credit: https://medium.com/@indiadigitalmarketing.info/difference-between-http-https-connection-e26c00a00383

HTTPS Connection

- Connection Initiation: HTTP client acts as the SSL/TLS client. It performs handshake. After the handshake finishes, a session is established and it sends the ordinary HTTP request. A session can support one or more connections at any time.
- Connection Closure: A client or a server may explicitly close a connection by issuing `Connection: close`. This indicates that the connection will be closed after this record is delivered.

Server decrypt

HTTPS Connection

Web designer define (not good to change)

https

```
<!-- index.html -->
<html>
  <body>
    <image src="http://www.example/img/insecure_photo1.jpg"/>
    <image src="https://www.example/img/secure_photo2.jpg"/>
    <image src="https://www.example/img/secure_photo3.jpg"/>
  </body>
</html>
```

- Even if `index.html` is transported over HTTPS, attacker would also knows you are accessing `insecure_photo1.jpg`
- Need to stop insecure connection from server level!

HSTS Insecure → Secure

- HTTP Strict Transport Security (HSTS) is a web security policy mechanism that is recommended to use together wit HTTPS.

When a server implements HSTS, the HTTP header should add a line

```
Strict-Transport-Security: max-age=31536000
```

The browser should then perform the following:

1. Turn any insecure links to secure links (i.e., http://example.com/page ➡ https://example.com/page).
2. If the connection cannot be ensured (i.e., cannot verify the public key of the server), abort.

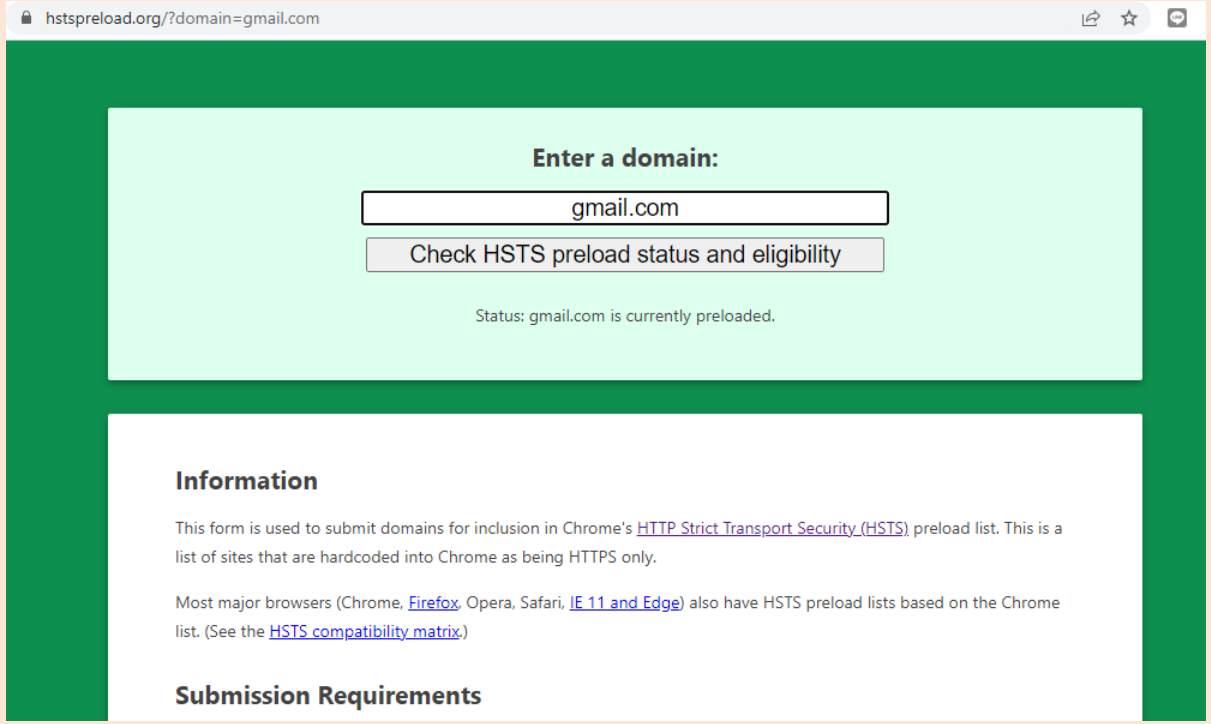
HSTS

强制执行

HSTS preload: A list of hosts that is enforcing `HSTS` by hard-coding into browsers (Chrome, Firefox, Safari, etc).

- This avoids attackers intercept and tamper with redirects that take place over HTTP.

拦截 篡改



https://hstspreload.org/ to register HSTS.

www.hkbu.com (HTTP default)

Server → redirect to

https://hkbu.com

Compare IPSec and TLS/SSL

- TLS/SSL is over a reliable transport (typically TCP), while IPsec is over an unreliable transport (IP, which can drop and reorder packets).
- IPsec was designed specifically to protect IP traffic; hence it has a bunch of rules built in with IP in mind; (e.g fragments/MTU/security policy database). TLS/SSL was designed to protect a byte stream, and it makes no assumptions about what that byte stream means.
- IPSec is gateway friendly, different protection mechanism can be in placed at beyond the gateway for example. TLS/SSL always assume it is point to point security.

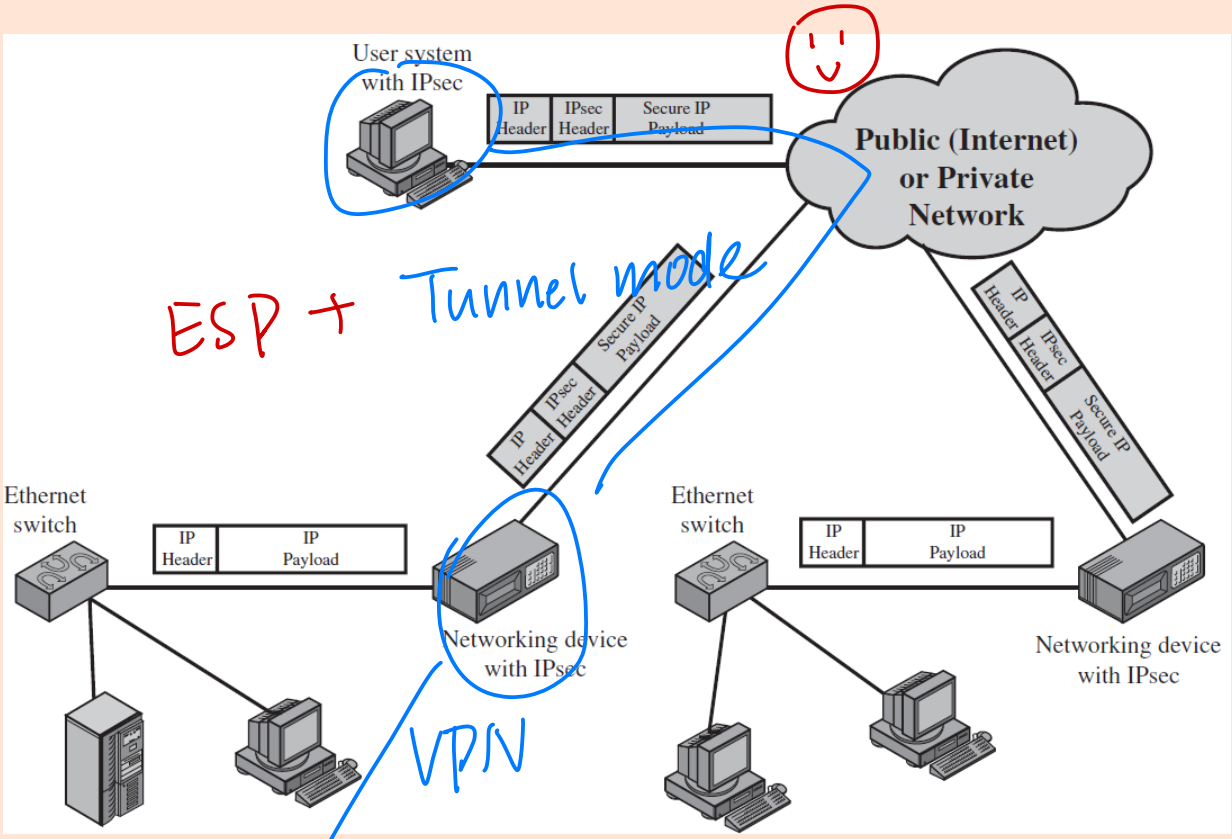
TLS/SSL commonly used in HTTPS
IPSec commonly used in VPN

https://crypto.stackexchange.com/questions/56354/ipsec-vs-ssl-similarities-and-differences

Virtual Private Networks

higher the traffic

- A corporate may have many sites. At each corporate site, workstations, servers, and databases are linked by one or more local area networks (LANs).
- These sites do not have a lease line / a private network connecting them. Instead, these sites directly connect to a public network (security risk!).
- A Virtual Private Network (VPN) uses encryption and authentication in the lower protocol layers to provide a secure connection over public networks.

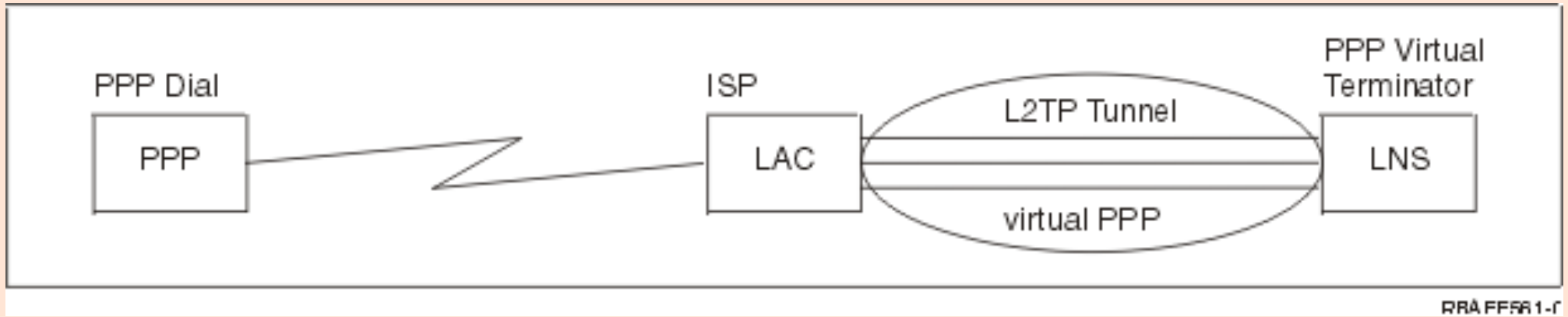


Toxic website

VPNs

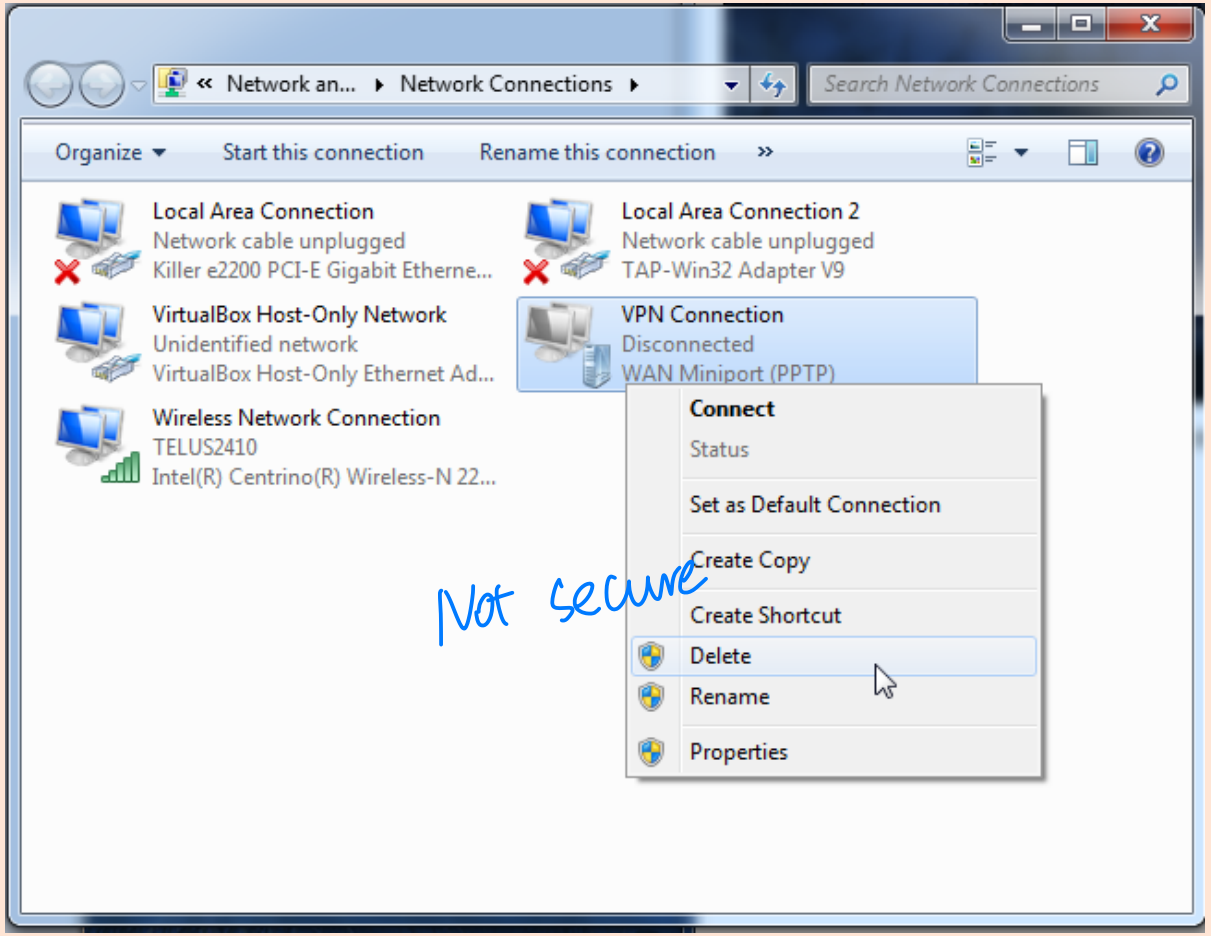
A VPN can be implemented by the followings:

1. IPSec. Both transport mode and tunnel mode are possible.
2. L2TP. Layer 2 Tunneling Protocol (L2TP) provides a tunneling service over UDP (but without encryption). It can used together with IPSec to provide a tunnel VPN. Packets does not need to be modified (e.g. IP translation) while using L2TP.
   L2TP is frequently mentioned with Point-to-Point Protocol (PPP), which is a TCP/IP protocol that is used for dial up service.



VPNs

3. Point-to-Point Tunneling Protocol (PPTP). It uses 128-bit encryption to provide tunneling service. It requires the port 1723 to work with. It can be easily blocked. Mainly appears on Windows system. It is considered less secure than other VPN protocols.
4. Secure Socket Tunneling Protocol (SSTP). A successor of PPTP mainly appears on Windows system. It provides a proprietary encryption standard owned by Microsoft.

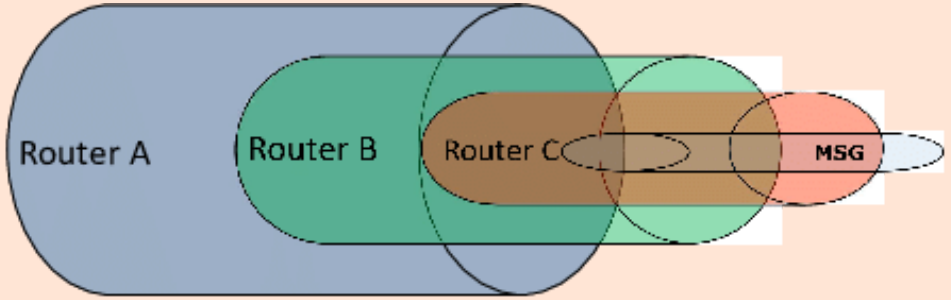


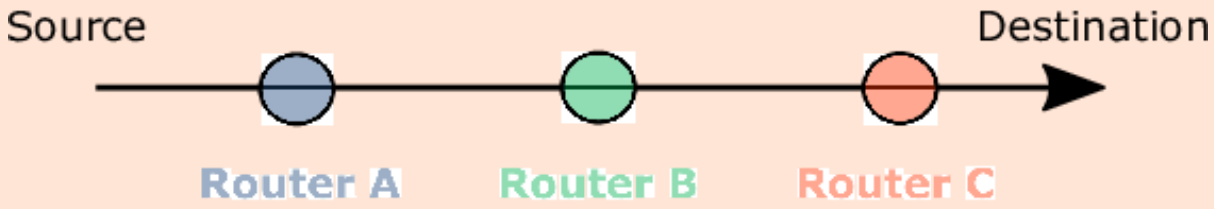
VPNs

5. SSL/TLS. A web-based VPN can be implemented using SSL/TLS. Without additional setup, a VPN can be done via a web browser directly. All traffic will go through the VPN server before reaching to the client.
6. OpenVPN. Built over open-source technologies like OpenSSL, SSL/TLS. It supports authentication using pre-shared keys, certificates, and passwords.
7. IKEv2. Internet Key Exchange protocol (IKE) itself is a protocol to establish key and authentication where it also can be used to setup SA in IPSec. This is provable secure.
8. OpenSSH. It is a secure shell for remote terminal access. It also supports tunnel mode and transport mode.

Onion Routing

- Onion routing is designed for anonymoizing conections for applications with low-latency constraints (e.g. web browsing).
- An onion routing network consists of a set of routers, forming a bidirectional circuit. 双向的
- Data are encrypted with "onion/layered" fashion.



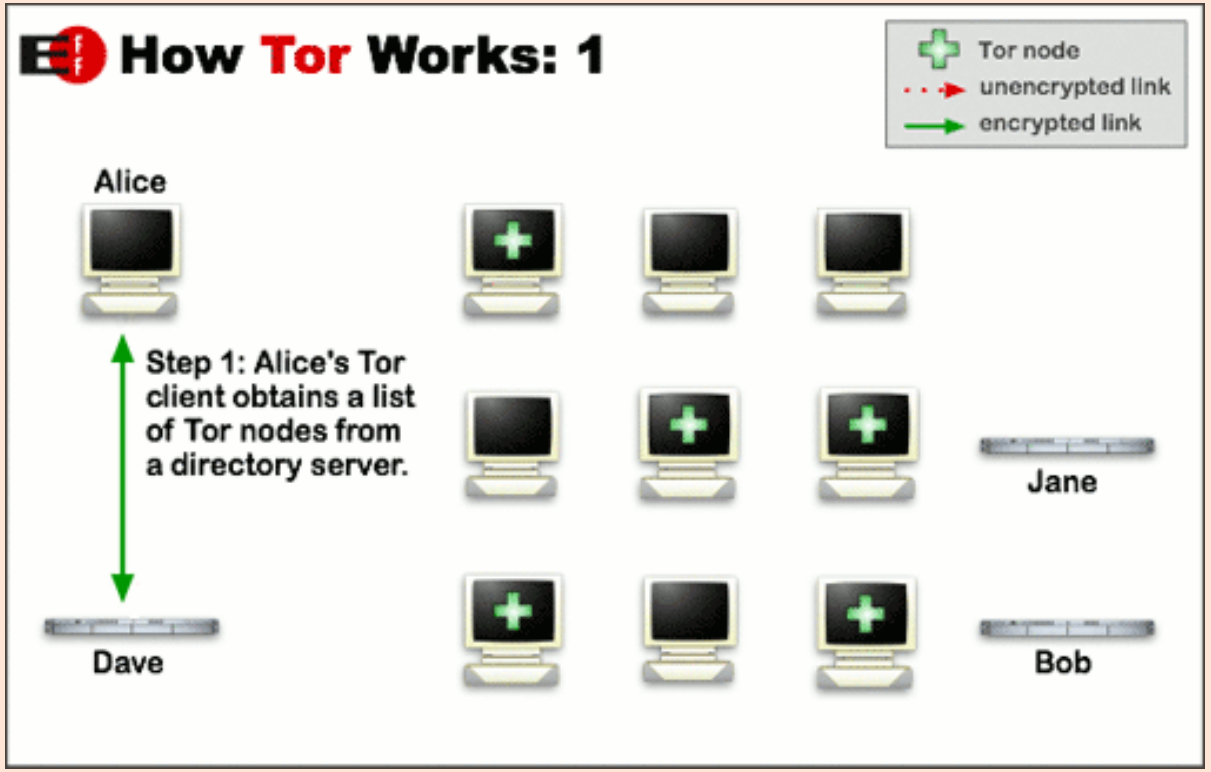


- Each router can decrypt its layer and forwards the data to the next router in the circuit. The last router forward the content to the destination.
- Each router only knows their predecessor and successor in the circuit. The complete sequence is known by the initiator only.

Shirazi et al. (2016). A Survey on Routing in Anonymous Communication Protocols. ACM Computing Surveys.

Onion Routing #1

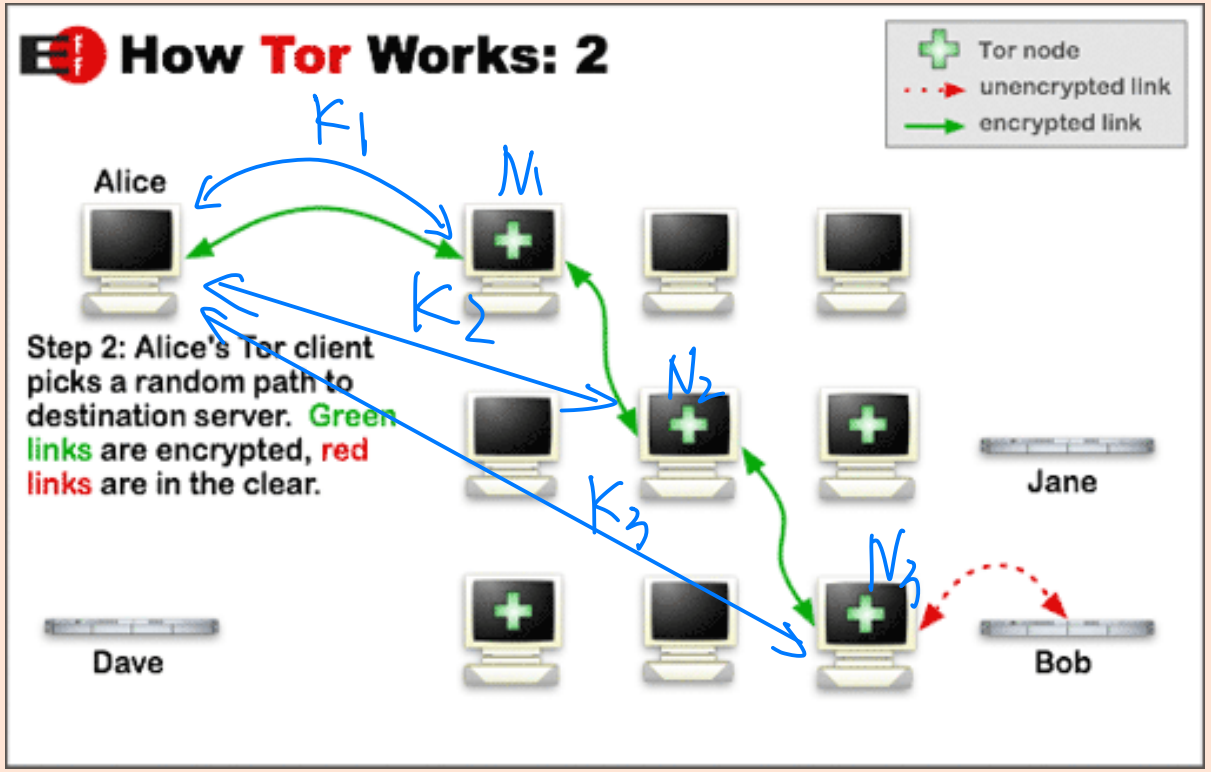
- To begin the service, a user Alice needs to obtain a list of Tor nodes from a directory server Dave.
- The list contains the IP address and the public key of the nodes.



img: torproject.org

Onion Routing #2

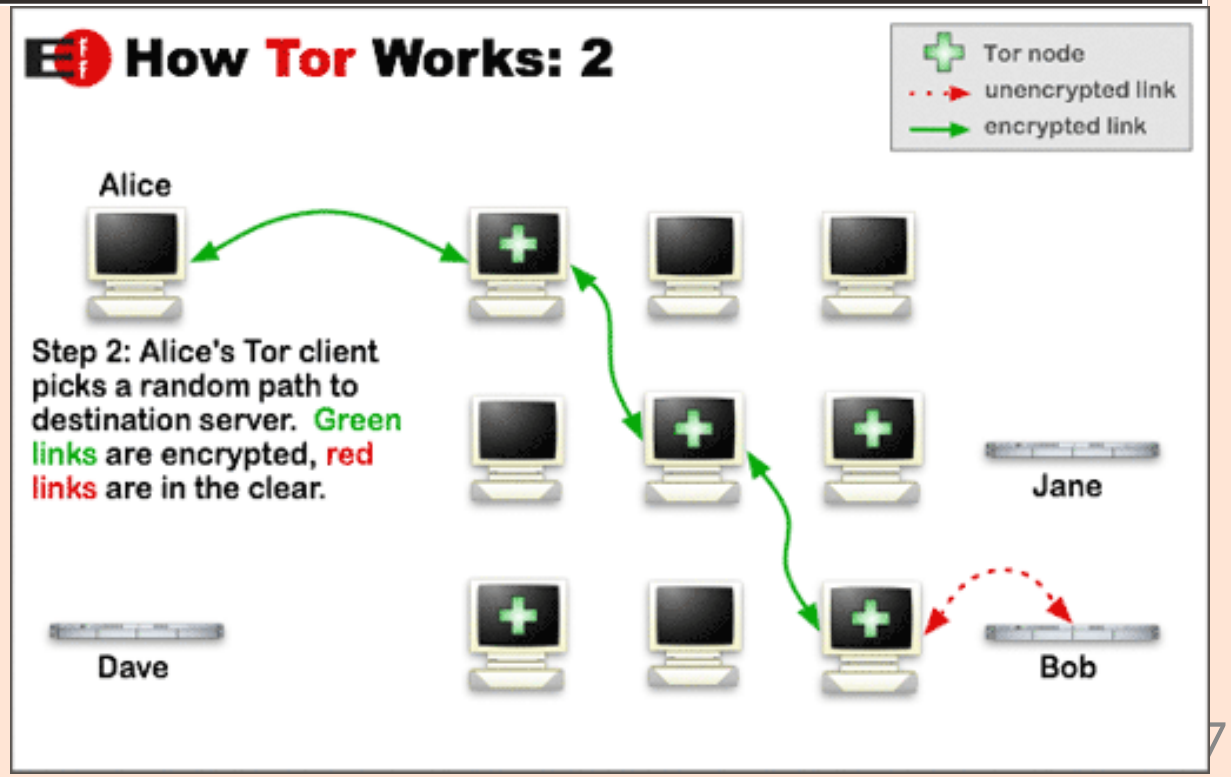
- Alice then use the public key of the entry node to establish a session key K_1 with it.
- Next, Alice will try to establish a session key with a middle node using the middle node's public key. To do that, Alice will prepare the key establishment packet, with the IP address of middle node, and encrypt it with K_1. The entry node (knowing K_1) will relay the message to middle node.



Onion Routing #2 (con't)

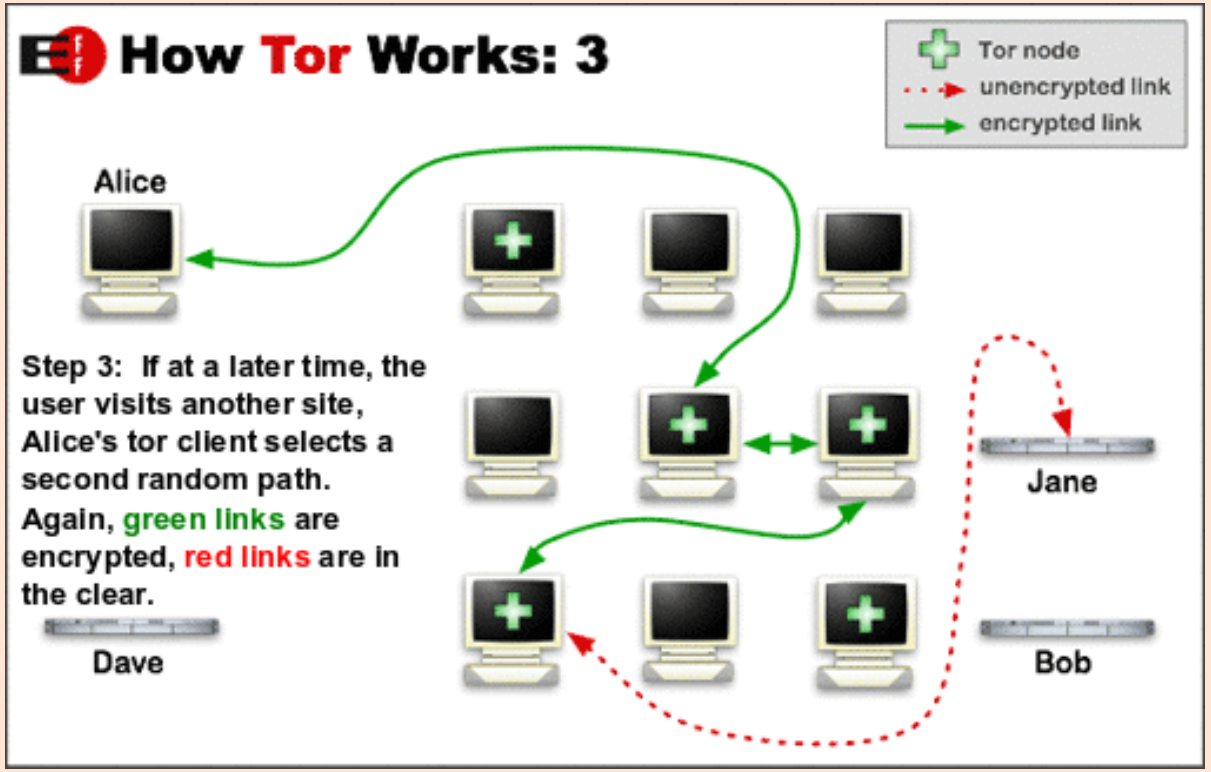
- The middle node should receive the message and establish a session key K_2 with Alice. Alice will repeat the step again to establish a session key with the exit node, by preparing a onion packet:

```
To Entry-Node IP: K_1{ To Middle-Node IP: K_2[ To Exit-Node IP: Pk_3{Setup} ] }
```



Onion Routing #3

- Eventually Alice will establish the keys K_1 with the entry node, K_2 with the middle node, K_3 with the exit node.
  - The entry node knows the location of Alice and the middle node, the middle node knows the entry node and the exit node.
  - The exit node knows the middle node.



- Alice then use this circuit to communicate to a remote server. The exit node will unwrap everything and contact the server without further onion encryption.
- Alice in a later time can select another random path when she wants to visit another website.

Onion Routing

Each node will only remember their predecessor and successor so that no node will be able to figure out the entire path.

Routing Table of Node X

From	From Port	Key	To	To Port
Node A	4233	`0x7622`	Node C	4995
Node D	9943	`0x4322`	Node E	29322
...				

When a packet returns from Node C from the port 4995. Node X knows it should be returned to Node A via the port 4233. Node X will use the key `0x7622` to encrypt the message before returning it to Node A.

Onion Routing

Computation

A circuit setup takes time because 1) public key establishment takes time; 2) a round-trip time for each node on the circuit to establish keys.
Once a circuit is formed, the speed will be increased (no more route discovery is needed). Each node only needs to decrypt the onion packet and reroute.

Routing

Because the onion nodes are randomly selected, they might not be near the server. These onion nodes may be also not close to each other. It can significantly increase the transportation time.

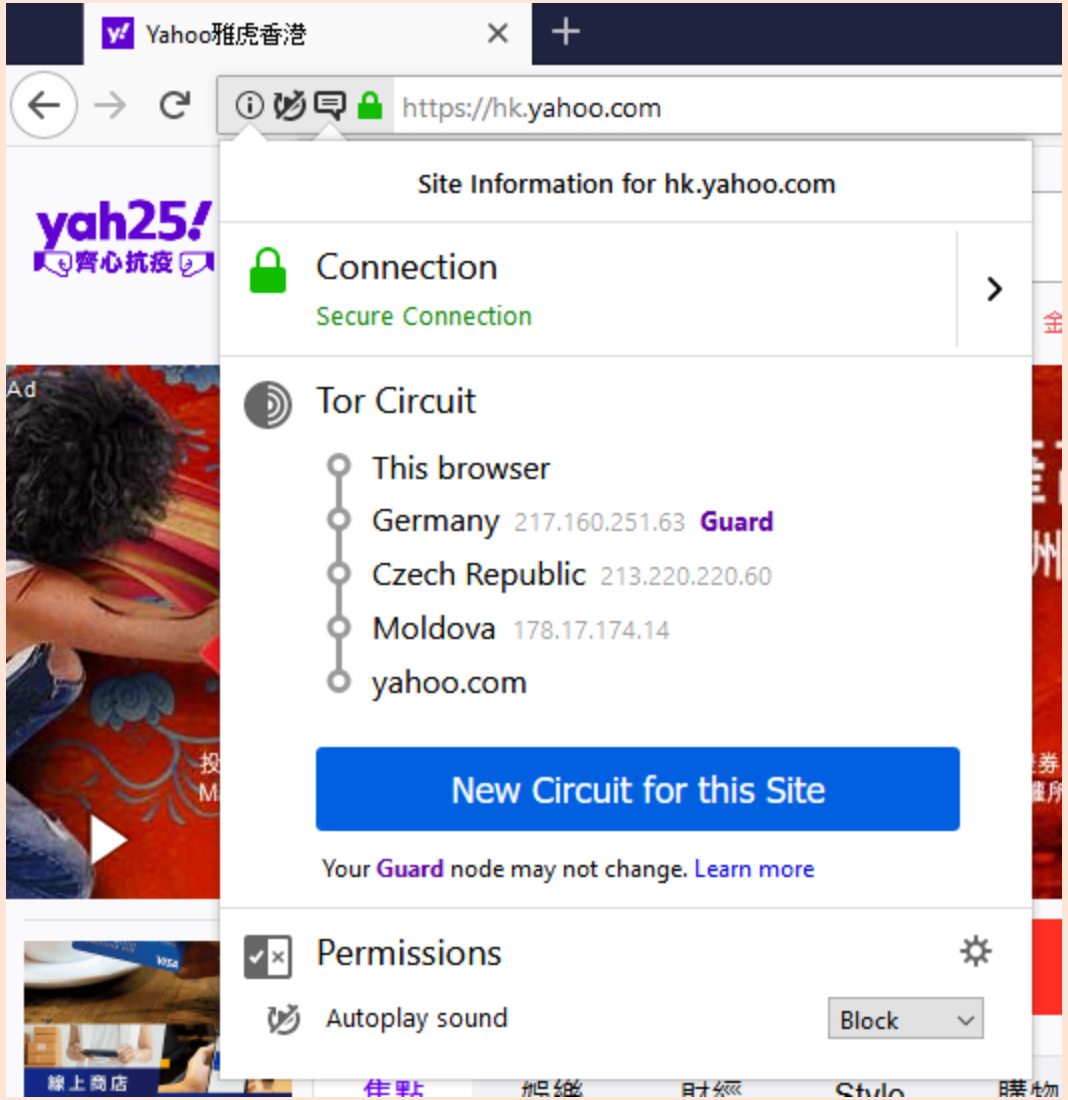
Exit node security

Content is not further encrypted in the exit node. To avoid the exit node reading the content, the message should be end-to-end encrypted (e.g. over HTTPS).

Hands-on work

Try Tor browser: torproject.org

- How is the speed compare with directly connected to a website?
- How can you verify that the website has no idea where are you connected from?



Summary

- IPSec
- TLS/SSL
- VPN
- Onion routing